



Payment Card Industry Data Security Standard

Self-Assessment Questionnaire A-EP and Attestation of Compliance

For use with PCI DSS Version 4.0.1

Publication Date: October 2024

Document Changes

Date	PCI DSS Version	SAQ Revision	Description
N/A	1.0		Not used.
N/A	2.0		Not used.
February 2014	3.0		New SAQ to address requirements applicable to e-commerce merchants with a website(s) that does not itself receive cardholder data but which does affect the security of the payment transaction and/or the integrity of the page that accepts the consumer's cardholder data. Content aligns with PCI DSS v3.0 requirements and testing procedures.
April 2015	3.1		Updated to align with PCI DSS v3.1. For details of PCI DSS changes, see <i>PCI DSS – Summary of Changes from PCI DSS Version 3.0 to 3.1</i> .
June 2015	3.1		Update Requirement 11.3 to fix error.
July 2015	3.1	1.1	Updated to remove references to "best practices" prior to June 30, 2015, and remove the PCI DSS v2 reporting option for Requirement 11.3
April 2016	3.2	1.0	Updated to align with PCI DSS v3.2. For details of PCI DSS changes, see <i>PCI DSS – Summary of Changes from PCI DSS Version 3.1 to 3.2</i> . Requirements added from PCI DSS v3.2 Requirements 1, 5, 6, 7, 8, 10, 11, and Appendix A2.
January 2017	3.2	1.1	Updated Document Changes to clarify requirements added in the April 2016 update.
June 2018	3.2.1	1.0	Updated to align with PCI DSS v3.2.1. For details of PCI DSS changes, see <i>PCI DSS – Summary of Changes from PCI DSS Version 3.2 to 3.2.1</i> .
April 2022	4.0		Updated to align with PCI DSS v4.0. For details of PCI DSS changes, see <i>PCI DSS – Summary of Changes from PCI DSS Version 3.2.1 to 4.0</i> . Rearranged, retitled, and expanded information in the "Completing the Self-Assessment Questionnaire" section (previously titled "Before You Begin"). Aligned content in Sections 1 and 3 of Attestation of Compliance (AOC) with PCI DSS v4.0 Report on Compliance AOC. Added PCI DSS v4.0 requirements. Added appendices to support new reporting responses.
December 2022	4.0	1	Removed "In Place with Remediation" as a reporting option from Requirement Responses table, Attestation of Compliance (AOC) Part 2g, SAQ Section 2 Response column, and AOC Section 3. Also removed former Appendix C. Added "In Place with CCW" to AOC Section 3. Added guidance for responding to future-dated requirements. Added minor clarifications and addressed typographical errors.
September 2023	4.0	2	Removed erroneous SAQ Completion Guidance at Requirement 11.6.1 – it is not applicable to SAQ A-EP merchants.
October 2024	4.0.1		Updated to align with PCI DSS v4.0.1. For details of PCI DSS changes, see <i>PCI DSS – Summary of Changes from PCI DSS Version 4.0 to 4.0.1</i> . Updated an SAQ Eligibility Criteria that the merchant has confirmed "their TPSP(s) are PCI DSS compliant for the services used by the merchant" rather than that the merchant has reviewed the TPSP(s)' AOCs. Added ASV Resource Guide to section "Additional PCI SSC Resources." Added SAQ Completion Guidance to Requirements 6.4.3 and 11.6.1.

Contents

Document Changes	i
Completing the Self-Assessment Questionnaire.....	iii
Merchant Eligibility Criteria for Self-Assessment Questionnaire A-EP.....	iii
Defining Account Data, Cardholder Data, and Sensitive Authentication Data	iv
PCI DSS Self-Assessment Completion Steps	iv
Expected Testing.....	iv
Requirement Responses.....	v
Additional PCI SSC Resources	vii
Section 1: Assessment Information	1
Section 2: Self-Assessment Questionnaire A-EP	4
Build and Maintain a Secure Network and Systems.....	4
<i>Requirement 1: Install and maintain network security controls.....</i>	<i>4</i>
<i>Requirement 2: Apply Secure Configurations to All System Components</i>	<i>9</i>
Protect Account Data.....	12
<i>Requirement 3: Protect Stored Account Data.....</i>	<i>12</i>
<i>Requirement 4: Protect Cardholder Data with Strong Cryptography During Transmission Over Open, Public Networks.....</i>	<i>16</i>
Maintain a Vulnerability Management Program	19
<i>Requirement 5: Protect All Systems and Networks from Malicious Software</i>	<i>19</i>
<i>Requirement 6: Develop and Maintain Secure Systems and Software</i>	<i>23</i>
Implement Strong Access Control Measures	31
<i>Requirement 7: Restrict Access to System Components and Cardholder Data by Business Need to Know</i>	<i>31</i>
<i>Requirement 8: Identify Users and Authenticate Access to System Components.....</i>	<i>33</i>
<i>Requirement 9: Restrict Physical Access to Cardholder Data.....</i>	<i>45</i>
Regularly Monitor and Test Networks	47
<i>Requirement 10: Log and Monitor All Access to System Components and Cardholder Data</i>	<i>47</i>
<i>Requirement 11: Test Security of Systems and Networks Regularly</i>	<i>52</i>
Maintain an Information Security Policy.....	59
<i>Requirement 12: Support Information Security with Organizational Policies and Programs</i>	<i>59</i>
Appendix A: Additional PCI DSS Requirements.....	66
<i>Appendix A1: Additional PCI DSS Requirements for Multi-Tenant Service Providers.....</i>	<i>66</i>
<i>Appendix A2: Additional PCI DSS Requirements for Entities using SSL/early TLS for Card-Present POS POI Terminal Connections.....</i>	<i>66</i>
<i>Appendix A3: Designated Entities Supplemental Validation (DESV).....</i>	<i>66</i>
Appendix B: Compensating Controls Worksheet.....	67
Appendix C: Explanation of Requirements Noted as Not Applicable.....	69
Appendix D: Explanation of Requirements Noted as Not Tested.....	71
Section 3: Validation and Attestation Details	72

Completing the Self-Assessment Questionnaire

Merchant Eligibility Criteria for Self-Assessment Questionnaire A-EP

Self-Assessment Questionnaire (SAQ) A-EP includes only those PCI DSS requirements applicable to e-commerce merchants with a website(s) that does not itself receive account data but which does affect the security of the payment transaction and/or the integrity of the page that accepts the customer's account data.

SAQ A-EP merchants are e-commerce merchants that partially outsource their e-commerce payment channel to PCI DSS validated and compliant third parties and do not electronically store, process, or transmit any account data on their systems or premises.

This SAQ is applicable only to e-commerce channels.

This SAQ is not applicable to service providers

SAQ A-EP merchants will confirm that they meet the following eligibility criteria for this payment channel:

- The merchant accepts only e-commerce transactions;
- All processing of account data, with the exception of the payment page, is entirely outsourced to a PCI DSS compliant third-party service provider (TPSP)/payment processor;
- The merchant's e-commerce website does not receive account data but controls how customers, or their account data, are redirected to a PCI DSS compliant TPSP/payment processor;
- If the merchant website is hosted by a TPSP, the TPSP is compliant with all applicable PCI DSS requirements (including PCI DSS Appendix A if the TPSP is a multi-tenant hosting provider);
- Each element of the payment page(s) delivered to the customer's browser originates from either the merchant's website or a PCI DSS compliant TPSP;
- The merchant does not electronically store, process, or transmit any account data on merchant systems or premises, but relies entirely on a TPSP(s) to handle all these functions;
- The merchant has confirmed that the TPSP(s) are PCI DSS compliant for the services used by the merchant; and
- Any account data the merchant might retain is on paper (for example, printed reports or receipts), and these documents are not received electronically.

This SAQ includes only those requirements that apply to a specific type of merchant environment, as defined in the above eligibility criteria. If there are PCI DSS requirements applicable to the cardholder data environment that are not covered in this SAQ, it may be an indication that this SAQ is not suitable for the merchant's environment.

Note: For the purposes of this SAQ, PCI DSS requirements that refer to the "cardholder data environment" are applicable to the merchant website(s). This is because the merchant website directly impacts how account data is transmitted, even though the website itself does not receive account data.

Defining Account Data, Cardholder Data, and Sensitive Authentication Data

PCI DSS is intended for all entities that store, process, or transmit cardholder data (CHD) and/or sensitive authentication data (SAD) or could impact the security of cardholder data and/or sensitive authentication data. Cardholder data and sensitive authentication data are considered account data and are defined as follows:

Account Data	
Cardholder Data includes:	Sensitive Authentication Data includes:
- Primary Account Number (PAN) - Cardholder Name - Expiration Date - Service Code	- Full track data (magnetic-stripe data or equivalent on a chip) - Card verification code - PINs/PIN blocks

Refer to PCI DSS Section 2, *PCI DSS Applicability Information*, for further details.

PCI DSS Self-Assessment Completion Steps

- Confirm by review of the eligibility criteria in this SAQ and the *Self-Assessment Questionnaire Instructions and Guidelines* document on the PCI SSC website that this is the correct SAQ for the merchant's environment.
- Confirm that the merchant environment is properly scoped.
- Assess the environment for compliance with PCI DSS requirements.
- Complete all sections of this document:
 - Section 1: Assessment Information (Parts 1 & 2 of the Attestation of Compliance (AOC) – Contact Information and Executive Summary).
 - Section 2 –Self-Assessment Questionnaire A-EP.
 - Section 3: Validation and Attestation Details (Parts 3 & 4 of the AOC – PCI DSS Validation and Action Plan for Non-Compliant Requirements (if Part 4 is applicable)).
- Submit the SAQ and AOC, along with any other requested documentation—such as ASV scan reports—to the requesting organization (those organizations that manage compliance programs such as payment brands and acquirers).

Expected Testing

The instructions provided in the “Expected Testing” column are based on the testing procedures in PCI DSS and provide a high-level description of the types of testing activities that a merchant is expected to perform to verify that a requirement has been met.

The intent behind each testing method is described as follows:

- Examine:** The merchant critically evaluates data evidence. Common examples include documents (electronic or physical), screenshots, configuration files, audit logs, and data files.
- Observe:** The merchant watches an action or views something in the environment. Examples of observation subjects include personnel performing a task or process, system components performing a function or responding to input, environmental conditions, and physical controls.

- Interview: The merchant converses with individual personnel. Interview objectives may include confirmation of whether an activity is performed, descriptions of how an activity is performed, and whether personnel have particular knowledge or understanding.

The testing methods are intended to allow the merchant to demonstrate how it has met a requirement. The specific items to be examined or observed and personnel to be interviewed should be appropriate for both the requirement being assessed and the entity's particular implementation.

Full details of testing procedures for each requirement can be found in PCI DSS.

Requirement Responses

For each requirement item, there is a choice of responses to indicate the merchant's status regarding that requirement. **Only one response should be selected for each requirement item.**

A description of the meaning for each response and when to use each response is provided in the table below:

Response	When to use this response:
In Place	The expected testing has been performed, and all elements of the requirement have been met as stated.
In Place with CCW (Compensating Controls Worksheet)	The expected testing has been performed, and the requirement has been met with the assistance of a compensating control. All responses in this column require completion of a Compensating Controls Worksheet (CCW) in Appendix B of this SAQ. Information on the use of compensating controls and guidance on how to complete the worksheet is provided in PCI DSS in Appendices B and C.
Not Applicable	The requirement does not apply to the merchant's environment. (See "Guidance for Not Applicable Requirements" below for examples.) All responses in this column require a supporting explanation in Appendix C of this SAQ.
Not Tested	<i>The response is not applicable to, and not included as an option for, this SAQ.</i> <i>This SAQ was created for a specific type of environment based on how the merchant stores, processes, and/or transmits account data and defines the specific PCI DSS requirements that apply for this environment. Consequently, all requirements in this SAQ must be tested.</i>
Not in Place	Some or all elements of the requirement have not been met, or are in the process of being implemented, or require further testing before the merchant can confirm they are in place. Responses in this column may require the completion of Part 4, if requested by the entity to which this SAQ will be submitted. This response is also used if a requirement cannot be met due to a legal restriction. (See "Legal Exception" below for more guidance).

Guidance for Not Applicable Requirements

If any requirements do not apply to the merchant's environment, select the Not Applicable option for that specific requirement. For example, in this SAQ, requirements for securing all media with cardholder data (Requirements 9.4.1 - 9.4.6) only apply if a merchant stores paper media with cardholder data; if paper media is not stored, the merchant can select Not Applicable for those requirements.

For each response where Not Applicable is selected in this SAQ, complete *Appendix C: Explanation of Requirements Noted as Not Applicable*.

Guidance for Responding to Future Dated Requirements

In Section 2 below, each PCI DSS requirement or bullet with an extended implementation period includes the following note: *"This requirement [or bullet] is a best practice until 31 March 2025, after which it will be required and must be fully considered during a PCI DSS assessment."*

These new requirements are not required to be included in a PCI DSS assessment until the future date has passed. Prior to that future date, any requirements with an extended implementation date that have not been implemented by the merchant may be marked as Not Applicable and documented in *Appendix C: Explanation of Requirements Noted as Not Applicable*.

Legal Exception

If your organization is subject to a legal restriction that prevents the organization from meeting a PCI DSS requirement, select Not in Place for that requirement and complete the relevant attestation in Section 3, Part 3 of this SAQ.

Note: *A legal exception is a legal restriction due to a local or regional law, regulation, or regulatory requirement, where meeting a PCI DSS requirement would violate that law, regulation, or regulatory requirement.*

Contractual obligations or legal advice are not legal restrictions.

Use of the Customized Approach

SAQs cannot be used to document use of the Customized Approach to meet PCI DSS requirements. For this reason, the Customized Approach Objectives are not included in SAQs. Entities wishing to validate using the Customized Approach may be able to use the PCI DSS Report on Compliance (ROC) Template to document the results of their assessment.

Use of the Customized Approach is not supported in SAQs.

The use of the customized approach may be regulated by organizations that manage compliance programs, such as payment brands and acquirers. Questions about use of a customized approach should always be referred to those organizations. This includes whether an entity that is eligible for an SAQ may instead complete a ROC to use a customized approach, and whether an entity is required to use a QSA, or may use an ISA, to complete an assessment using the customized approach. Information about the use of the Customized Approach can be found in Appendices D and E of PCI DSS.

Additional PCI SSC Resources

Additional resources that provide guidance on PCI DSS requirements and how to complete the self-assessment questionnaire have been provided below to assist with the assessment process.

Resource	Includes:
PCI Data Security Standard Requirements and Testing Procedures (PCI DSS)	▪ Guidance on Scoping ▪ Guidance on the intent of all PCI DSS Requirements ▪ Details of testing procedures ▪ Guidance on Compensating Controls ▪ Appendix G: Glossary of Terms, Abbreviations, and Acronyms
SAQ Instructions and Guidelines	▪ Information about all SAQs and their eligibility criteria ▪ How to determine which SAQ is right for your organization
Frequently Asked Questions (FAQs)	▪ Guidance and information about SAQs.
Online PCI DSS Glossary	▪ PCI DSS Terms, Abbreviations, and Acronyms
Information Supplements and Guidelines	▪ Guidance on a variety of PCI DSS topics including: – <i>Understanding PCI DSS Scoping and Network Segmentation</i> – <i>Third-Party Security Assurance</i> – <i>Multi-Factor Authentication Guidance</i> – <i>Best Practices for Maintaining PCI DSS Compliance</i>
Getting Started with PCI	▪ Resources for smaller merchants including: – <i>Guide to Safe Payments</i> – <i>Common Payment Systems</i> – <i>Questions to Ask Your Vendors</i> – <i>Glossary of Payment and Information Security Terms</i> – <i>PCI Firewall Basics</i> – <i>ASV Resource Guide</i>

These and other resources can be found on the PCI SSC website (www.pcisecuritystandards.org).

Organizations are encouraged to review PCI DSS and other supporting documents before beginning an assessment.

Section 1: Assessment Information

Instructions for Submission

This document must be completed as a declaration of the results of the merchant's self-assessment against the *Payment Card Industry Data Security Standard (PCI DSS) Requirements and Testing Procedures*. Complete all sections. The merchant is responsible for ensuring that each section is completed by the relevant parties, as applicable. Contact the entity(ies) to which the Attestation of Compliance (AOC) will be submitted for reporting and submission procedures.

Part 1. Contact Information	
Part 1a. Assessed Merchant	
Company name:	WorkUp
DBA (doing business as):	WorkUp
Company mailing address:	Lab / Portfolio
Company main website:	https://victorojeje.xyz
Company contact name:	Victor Ogechukwu Ojeje
Company contact title:	Platform Operator
Contact phone number:	
Contact e-mail address:	ojejevictor@gmail.com
Part 1b. Assessor	
Provide the following information for all assessors involved in the assessment. If there was no assessor for a given assessor type, enter Not Applicable.	
PCI SSC Internal Security Assessor(s)	
ISA name(s):	Not Applicable
Qualified Security Assessor	
Company name:	Not Applicable
Company mailing address:	Not Applicable
Company website:	Not Applicable
Lead Assessor name:	Not Applicable
Assessor phone number:	Not Applicable
Assessor e-mail address:	Not Applicable
Assessor certificate number:	Not Applicable

Part 2. Executive Summary

Part 2a. Merchant Business Payment Channels (select all that apply):

Indicate all payment channels used by the business that are included in this assessment.

- ☐ Mail order/telephone order (MOTO)
- ☒ E-Commerce
- ☐ Card-present

Are any payment channels not included in this assessment?

☐ Yes ☒ No

If yes, indicate which channel(s) is not included in the assessment and provide a brief explanation about why the channel was excluded.

Note: If the organization has a payment channel that is not covered by this SAQ, consult with the entity(ies) to which this AOC will be submitted about validation for the other channels.

Part 2b. Description of Role with Payment Cards

For each payment channel included in this assessment as selected in Part 2a above, describe how the business stores, processes and/or transmits account data.

Channel	How Business Stores, Processes, and/or Transmits Account Data
E-Commerce	WorkUp does not store, process, or transmit cardholder data. Payment collection uses Stripe Embedded Checkout. Card data is entered only inside Stripe-controlled fields. WorkUp systems receive only Stripe tokens/events and never see PAN, expiry, or CVV

Part 2c. Description of Payment Card Environment

Provide a **high-level** description of the environment covered by this assessment.

For example:

- Connections into and out of the cardholder data environment (CDE).
- Critical system components within the CDE, such as POI devices, databases, web servers, etc., and any other necessary payment components, as applicable.
- System components that could impact the security of account data.

WorkUp is a B2B project-management SaaS (\$49/month per workspace). Payment is collected via Stripe Embedded Checkout; cardholder data is entered only inside Stripe-controlled UI elements and never touches WorkUp systems.

Infrastructure: Four segmented Ubuntu 22.04 VMs on a private LAN (192.168.123.0/24) on Proxmox, each running an independent Docker Compose stack:

Frontend VM (192.168.123.21) — nginx static site serving billing.html and loading Stripe.js

Auth VM (192.168.123.22) — Keycloak realm workup

Backend VM (192.168.123.23) — Go/Gin API; creates Stripe checkout sessions, verifies signed webhooks

Observability VM (192.168.123.24) — Grafana / Loki / Prometheus

All inbound public traffic arrives via dedicated Cloudflare Tunnels per segment. No public IP addresses on any VM. The four VMs do not communicate on the internal network; all inter-segment traffic uses public Cloudflare Tunnel URLs only.

Stripe is the PCI DSS Level 1 service provider that handles all cardholder data.

Indicate whether the environment includes segmentation to reduce the scope of the assessment.

(Refer to “Segmentation” section of PCI DSS for guidance on segmentation.)

☒ Yes ☐ No

Part 2. Executive Summary (continued)

Part 2d. In-Scope Locations/Facilities

List all types of physical locations/facilities (for example, retail locations, corporate offices, data centers, call centers, and mail rooms) in scope for the PCI DSS assessment.

Facility Type	Total number of locations (How many locations of this type are in scope)	Location(s) of facility (city, country)
Example: Data centers	3	Boston, MA, USA
Home lab / self-hosted environment (Proxmox)	1	Lagos, Nigeria

Part 2e. PCI SSC Validated Products and Solutions

Does the merchant use any item identified on any PCI SSC Lists of Validated Products and Solutions*?

☐ Yes ☒ No

Provide the following information regarding each item the merchant uses from PCI SSC's Lists of Validated Products and Solutions.

Name of PCI SSC-validated Product or Solution	Version of Product or Solution	PCI SSC Standard to which product or solution was validated	PCI SSC listing reference number	Expiry date of listing (YYYY-MM-DD)
				YYYY-MM-DD
				YYYY-MM-DD
				YYYY-MM-DD
				YYYY-MM-DD
				YYYY-MM-DD
				YYYY-MM-DD
				YYYY-MM-DD
				YYYY-MM-DD
				YYYY-MM-DD
				YYYY-MM-DD
				YYYY-MM-DD

* For purposes of this document, "Lists of Validated Products and Solutions" means the lists of validated products, solutions, and/or components, appearing on the PCI SSC website (www.pcisecuritystandards.org)—for example, 3DS Software Development Kits, Approved PTS Devices, Validated Payment Software, Point to Point Encryption (P2PE) solutions, Software-Based PIN Entry on COTS (SPoC) solutions, Contactless Payments on COTS (CPoC) solutions, and Mobile Payments on COTS (MPoC) products.

Part 2. Executive Summary *(continued)*

Part 2f. Third-Party Service Providers

Does the merchant have relationships with one or more third-party service providers that:

Store, process, or transmit account data on the merchant's behalf (for example, payment gateways, payment processors, payment service providers (PSPs), and off-site storage)	☒ Yes ☐ No
Manage system components included in the scope of the merchant's PCI DSS assessment—for example, via network security control services, anti-malware services, security incident and event management (SIEM), contact and call centers, web-hosting services, and IaaS, PaaS, SaaS, and FaaS cloud providers.	☒ Yes ☐ No
Could impact the security of the merchant's CDE (for example, vendors providing support via remote access, and/or bespoke software developers)	☒ Yes ☐ No

If Yes:

Name of service provider:	Description of service(s) provided:
Stripe	Payment processor — Embedded Checkout. Handles all cardholder data collection, processing, and transmission. PCI DSS Level 1 Service Provider.
Cloudflare	CDN, WAF (Custom Rules), Tunnel, and Zero Trust Access. Provides the public edge and protects inbound traffic to all WorkUp services.

Note: Requirement 12.8 applies to all entities in this list.

Part 2. Executive Summary *(continued)*

Part 2g. Summary of Assessment

(SAQ Section 2 and related appendices)

Indicate below all responses that were selected for each PCI DSS requirement.

PCI DSS Requirement *	Requirement Responses			
	<i>More than one response may be selected for a given requirement. Indicate all responses that apply.</i>			
	In Place	In Place with CCW	Not Applicable	Not in Place
Requirement 1:	☒	☐	☐	☐
Requirement 2:	☒	☐	☐	☐
Requirement 3:	☐	☐	☒	☐
Requirement 4:	☐	☐	☒	☐
Requirement 5:	☐	☐	☒	☒
Requirement 6:	☒	☒	☐	☐
Requirement 7:	☒	☐	☐	☐
Requirement 8:	☒	☐	☐	☐
Requirement 9:	☐	☐	☒	☐
Requirement 10:	☒	☐	☐	☐
Requirement 11:	☒	☐	☐	☐
Requirement 12:	☒	☐	☐	☐

* PCI DSS Requirements indicated above refer to the requirements in Section 2 of this SAQ.

Part 2. Executive Summary *(continued)*

Part 2h. Eligibility to Complete SAQ A-EP

Merchant certifies eligibility to complete this Self-Assessment Questionnaire because, for this payment channel:

☒	The merchant accepts only e-commerce transactions.
☒	All processing of account data, with the exception of the payment page, is entirely outsourced to a PCI DSS compliant third-party service provider (TPSP)/payment processor.
☒	The merchant's e-commerce website does not receive account data but controls how customers, or their account data, are redirected to a PCI DSS compliant TPSP/payment processor.
☒	If merchant website is hosted by a TPSP, the TPSP is compliant with all applicable PCI DSS requirements (for example, including PCI DSS Appendix A if the TPSP is a multi-tenant hosting provider).
☒	Each element of the payment page(s) delivered to the customer's browser originates from either the merchant's website or a PCI DSS compliant TPSP.
☒	The merchant does not electronically store, process, or transmit any account data on merchant systems or premises, but relies entirely on a TPSP(s) to handle all these functions.
☒	The merchant has confirmed that TPSP(s) are PCI DSS compliant for the services used by the merchant.
☒	Any account data the merchant might retain is on paper (for example, printed reports or receipts), and these documents are not received electronically.

Section 2: Self-Assessment Questionnaire A-EP

Note: The following requirements mirror the requirements in the PCI DSS Requirements and Testing Procedures document.

Self-assessment completion date: 2026-09-23

Build and Maintain a Secure Network and Systems

Requirement 1: Install and maintain network security controls

PCI DSS Requirement		Expected Testing	Response* (Check one response for each requirement)			
			In Place	In Place with CCW	Not Applicable	Not in Place
1.1 Processes and mechanisms for installing and maintaining network security controls are defined and understood.						
1.1.1	All security policies and operational procedures that are identified in Requirement 1 are: ▪ Documented. ▪ Kept up to date. ▪ In use. ▪ Known to all affected parties.	▪ Examine documentation. ▪ Interview personnel.	☒	☐	☐	☐
1.2 Network security controls (NSCs) are configured and maintained.						
1.2.1	Configuration standards for NSC rulesets are: ▪ Defined. ▪ Implemented. ▪ Maintained.	▪ Examine configurations standards. ▪ Examine configuration settings.	☒	☐	☐	☐

* Refer to the "Requirement Responses" section (page v) for information about these response options.

PCI DSS Requirement		Expected Testing	Response* (Check one response for each requirement)			
			In Place	In Place with CCW	Not Applicable	Not in Place
1.2.2	All changes to network connections and to configurations of NSCs are approved and managed in accordance with the change control process defined at Requirement 6.5.1.	- Examine documented procedures. - Examine network configurations. - Examine change control records. - Interview responsible personnel.	☒	☐	☐	☐
Applicability Notes						
Changes to network connections include the addition, removal, or modification of a connection. Changes to NSC configurations include those related to the component itself as well as those affecting how it performs its security function.						
1.2.3	An accurate network diagram(s) is maintained that shows all connections between the CDE and other networks, including any wireless networks.	- Examine network diagrams. - Examine network configurations. - Interview responsible personnel.	☒	☐	☐	☐
Applicability Notes						
A current network diagram(s) or other technical or topological solution that identifies network connections and devices can be used to meet this requirement.						
1.2.4	An accurate data-flow diagram(s) is maintained that meets the following: - Shows all account data flows across systems and networks. - Updated as needed upon changes to the environment.	- Examine data flow diagrams. - Observe network configurations. - Examine documentation. - Interview responsible personnel.	☒	☐	☐	☐
Applicability Notes						
A data-flow diagram(s) or other technical or topological solution that identifies flows of account data across systems and networks can be used to meet this requirement.						
1.2.5	All services, protocols and ports allowed are identified, approved, and have a defined business need.	- Examine documentation. - Examine configuration settings.	☒	☐	☐	☐
1.2.6	Security features are defined and implemented for all services, protocols, and ports that are in use and considered to be insecure, such that the risk is mitigated.	- Examine documentation. - Examine configuration settings.	☒	☐	☐	☐

PCI DSS Requirement		Expected Testing	Response* (Check one response for each requirement)			
			In Place	In Place with CCW	Not Applicable	Not in Place
1.2.7	Configurations of NSCs are reviewed at least once every six months to confirm they are relevant and effective.	- Examine documented procedures. - Examine documentation from reviews performed. - Examine configuration settings.	☒	☐	☐	☐
1.2.8	Configuration files for NSCs are: - Secured from unauthorized access. - Kept consistent with active network configurations.	Examine NSC configuration files.	☒	☐	☐	☐
Applicability Notes						
Any file or setting used to configure or synchronize NSCs is considered to be a "configuration file." This includes files, automated and system-based controls, scripts, settings, infrastructure as code, or other parameters that are backed up, archived, or stored remotely.						
1.3 Network access to and from the cardholder data environment is restricted.						
1.3.1	Inbound traffic to the CDE is restricted as follows: - To only traffic that is necessary. - All other traffic is specifically denied.	- Examine NSC configuration standards. - Examine NSC configurations.	☒	☐	☐	☐
1.3.2	Outbound traffic from the CDE is restricted as follows: - To only traffic that is necessary. - All other traffic is specifically denied.	- Examine NSC configuration standards. - Examine NSC configurations.	☒	☐	☐	☐
1.3.3	NSCs are installed between all wireless networks and the CDE, regardless of whether the wireless network is a CDE, such that: - All wireless traffic from wireless networks into the CDE is denied by default. - Only wireless traffic with an authorized business purpose is allowed into the CDE.	- Examine configuration settings. - Examine network diagrams.	☐	☐	☒	☐
1.4 Network connections between trusted and untrusted networks are controlled.						
1.4.1	NSCs are implemented between trusted and untrusted networks.	- Examine NSC configuration standards. - Examine current network diagrams. - Examine network configurations.	☒	☐	☐	☐

PCI DSS Requirement		Expected Testing	Response* (Check one response for each requirement)			
			In Place	In Place with CCW	Not Applicable	Not in Place
1.4.2	Inbound traffic from untrusted networks to trusted networks is restricted to: - Communications with system components that are authorized to provide publicly accessible services, protocols, and ports. - Stateful responses to communications initiated by system components in a trusted network. - All other traffic is denied.	- Examine NSC documentation. - Examine NSC configurations.	☒	☐	☐	☐
	Applicability Notes The intent of this requirement is to address communication sessions between trusted and untrusted networks, rather than the specifics of protocols. This requirement does not limit the use of UDP or other connectionless network protocols if state is maintained by the NSC.					
1.4.3	Anti-spoofing measures are implemented to detect and block forged source IP addresses from entering the trusted network.	- Examine NSC documentation. - Examine NSC configurations.	☒	☐	☐	☐
1.4.4	System components that store cardholder data are not directly accessible from untrusted networks.	- Examine the data-flow diagram and network diagram. - Examine NSC configurations.	☒	☐	☐	☐
	Applicability Notes This requirement is not intended to apply to storage of account data in volatile memory but does apply where memory is being treated as persistent storage (for example, RAM disk). Account data can only be stored in volatile memory during the time necessary to support the associated business process (for example, until completion of the related payment card transaction).					
1.4.5	The disclosure of internal IP addresses and routing information is limited to only authorized parties.	- Examine NSC configurations. - Examine documentation. - Interview responsible personnel.	☒	☐	☐	☐

PCI DSS Requirement		Expected Testing	Response* (Check one response for each requirement)			
			In Place	In Place with CCW	Not Applicable	Not in Place
1.5 Risks to the CDE from computing devices that are able to connect to both untrusted networks and the CDE are mitigated.						
1.5.1	Security controls are implemented on any computing devices, including company- and employee-owned devices, that connect to both untrusted networks (including the Internet) and the CDE as follows: • Specific configuration settings are defined to prevent threats being introduced into the entity's network. • Security controls are actively running. • Security controls are not alterable by users of the computing devices unless specifically documented and authorized by management on a case-by-case basis for a limited period.	• Examine policies and configuration standards. • Examine device configuration settings.	☒	☐	☐	☐
Applicability Notes						
These security controls may be temporarily disabled only if there is legitimate technical need, as authorized by management on a case-by-case basis. If these security controls need to be disabled for a specific purpose, it must be formally authorized. Additional security measures may also need to be implemented for the period during which these security controls are not active. This requirement applies to employee-owned and company-owned computing devices. Systems that cannot be managed by corporate policy introduce weaknesses and provide opportunities that malicious individuals may exploit.						

Requirement 2: Apply Secure Configurations to All System Components

Note: For SAQ A-EP, Requirement 2 applies to configurations and accounts on web servers and supporting systems that could impact the security of the web server.

PCI DSS Requirement		Expected Testing	Response* (Check one response for each requirement)			
			In Place	In Place with CCW	Not Applicable	Not in Place
2.1 Processes and mechanisms for applying secure configurations to all system components are defined and understood.						
2.1.1	All security policies and operational procedures that are identified in Requirement 2 are: - Documented. - Kept up to date. - In use. - Known to all affected parties.	- Examine documentation. - Interview personnel.	☒	☐	☐	☐
2.2 System components are configured and managed securely.						
2.2.1	Configuration standards are developed, implemented, and maintained to: - Cover all system components. - Address all known security vulnerabilities. - Be consistent with industry-accepted system hardening standards or vendor hardening recommendations. - Be updated as new vulnerability issues are identified, as defined in Requirement 6.3.1. - Be applied when new systems are configured and verified as in place before or immediately after a system component is connected to a production environment.	- Examine system configuration standards. - Review industry-accepted hardening standards. - Examine configuration settings. - Interview personnel.	☒	☐	☐	☐

* Refer to the "Requirement Responses" section (page v) for information about these response options.

PCI DSS Requirement	Expected Testing	Response* (Check one response for each requirement)			
		In Place	In Place with CCW	Not Applicable	Not in Place
2.2.2 Vendor default accounts are managed as follows: - If the vendor default account(s) will be used, the default password is changed per Requirement 8.3.6. - If the vendor default account(s) will not be used, the account is removed or disabled.	- Examine system configuration standards. - Examine vendor documentation. - Observe a system administrator logging on using vendor default accounts. - Examine configuration files. - Interview personnel.	☒	☐	☐	☐
Applicability Notes This applies to ALL vendor default accounts and passwords, including, but not limited to, those used by operating systems, software that provides security services, application and system accounts, point-of-sale (POS) terminals, payment applications, and Simple Network Management Protocol (SNMP) defaults. This requirement also applies where a system component is not installed within an entity's environment, for example, software and applications that are part of the CDE and are accessed via a cloud subscription service.					
2.2.3 Primary functions requiring different security levels are managed as follows: - Only one primary function exists on a system component, OR - Primary functions with differing security levels that exist on the same system component are isolated from each other, OR - Primary functions with differing security levels on the same system component are all secured to the level required by the function with the highest security need.	- Examine system configuration standards. - Examine system configurations.	☒	☐	☐	☐
2.2.4 Only necessary services, protocols, daemons, and functions are enabled, and all unnecessary functionality is removed or disabled.	- Examine system configuration standards. - Examine system configurations.	☒	☐	☐	☐

PCI DSS Requirement		Expected Testing	Response* (Check one response for each requirement)			
			In Place	In Place with CCW	Not Applicable	Not in Place
2.2.5	If any insecure services, protocols, or daemons are present: • Business justification is documented. • Additional security features are documented and implemented that reduce the risk of using insecure services, protocols, or daemons.	• Examine configuration standards. • Interview personnel. • Examine configuration settings.	☐	☐	☒	☐
2.2.6	System security parameters are configured to prevent misuse.	• Examine system configuration standards. • Interview personnel. • Examine system configurations.	☒	☐	☐	☐
2.2.7	All non-console administrative access is encrypted using strong cryptography.	• Examine system configuration standards. • Observe an administrator log on. • Examine system configurations. • Examine vendor documentation. • Interview personnel.	☒	☐	☐	☐
Applicability Notes						
This includes administrative access via browser-based interfaces and application programming interfaces (APIs).						

Protect Account Data

Requirement 3: Protect Stored Account Data

Note: For SAQ A-EP, Requirement 3 applies only to merchants with paper records that include account data (for example, receipts or printed reports).

PCI DSS Requirement		Expected Testing	Response* (Check one response for each requirement)			
			In Place	In Place with CCW	Not Applicable	Not in Place
3.1 Processes and mechanisms for protecting stored account data are defined and understood.						
3.1.1	All security policies and operational procedures that are identified in Requirement 3 are: - Documented. - Kept up to date. - In use. - Known to all affected parties.	- Examine documentation. - Interview personnel.	☐	☐	☒	☐
SAQ Completion Guidance: Selection of any of the In Place responses for Requirement 3.1.1 means that, if the merchant has paper storage of account data, the merchant has policies and procedures in place that govern merchant activities for Requirement 3. This helps to ensure personnel are aware of and following security policies and documented operational procedures for managing the secure storage of any paper records with account data. If merchant does not store paper records with account data, mark this requirement as Not Applicable and complete Appendix C: Explanation of Requirements Noted as Not Applicable.						

* Refer to the "Requirement Responses" section (page v) for information about these response options.

PCI DSS Requirement		Expected Testing	Response* (Check one response for each requirement)			
			In Place	In Place with CCW	Not Applicable	Not in Place
3.2 Storage of account data is kept to a minimum.						
3.2.1	Account data storage is kept to a minimum through implementation of data retention and disposal policies, procedures, and processes that include at least the following: - Coverage for all locations of stored account data. - Coverage for any sensitive authentication data (SAD) stored prior to completion of authorization. <i>This bullet is a best practice until its effective date; refer to Applicability Notes below for details.</i> - Limiting data storage amount and retention time to that which is required for legal or regulatory, and/or business requirements. - Specific retention requirements for stored account data that defines length of retention period and includes a documented business justification. - Processes for secure deletion or rendering account data unrecoverable when no longer needed per the retention policy. - A process for verifying, at least once every three months, that stored account data exceeding the defined retention period has been securely deleted or rendered unrecoverable.	- Examine the data retention and disposal policies, procedures, and processes. - Interview personnel. - Examine files and system records on system components where account data is stored. - Observe the mechanisms used to render account data unrecoverable.	☐	☐	☒	☐
Applicability Notes (continued)						
3.2.1 (cont.)	Part of this Applicability Note was intentionally removed as it does not apply to SAQ A-EP assessments. <i>The bullet above (for coverage of SAD stored prior to completion of authorization) is a best practice until 31 March 2025, after which it will be required as part of Requirement 3.2.1 and must be fully considered during a PCI DSS assessment.</i>					

PCI DSS Requirement		Expected Testing	Response* (Check one response for each requirement)			
			In Place	In Place with CCW	Not Applicable	Not in Place
SAQ Completion Guidance: Selection of any of the In Place responses for Requirement 3.2.1 means that if a merchant stores any paper (for example, receipts or paper reports) that contain account data, the merchant only stores the paper as long as it is needed for business, legal, and/or regulatory reasons and destroys the paper once it is no longer needed. If a merchant never prints or stores any paper containing account data, mark this requirement as Not Applicable and complete Appendix C: Explanation of Requirements Noted as Not Applicable.						
3.3 Sensitive authentication data (SAD) is not stored after authorization.						
3.3.1	SAD is not stored after authorization, even if encrypted. All sensitive authentication data received is rendered unrecoverable upon completion of the authorization process. Applicability Notes <i>Part of this Applicability Note was intentionally removed for this SAQ as it does not apply to merchant assessments.</i> Sensitive authentication data includes the data cited in Requirements 3.3.1.2 through 3.3.1.3.	- Examine documented policies and procedures. - Examine system configurations. - Observe the secure data deletion processes.	☐	☐	☒	☐
3.3.1.2	The card verification code is not stored upon completion of the authorization process. Applicability Notes The card verification code is the three- or four-digit number printed on the front or back of a payment card used to verify card-not-present transactions.	Examine data sources.	☐	☐	☒	☐
SAQ Completion Guidance: Selection of any of the In Place responses for Requirement 3.3.1.2 means that if the merchant writes down the card verification code while a transaction is being conducted, the merchant either securely destroys the paper (for example, with a shredder) immediately after the transaction is complete, or obscures the code (for example, by “blacking it out” with a marker) before the paper is stored. If the merchant never requests the three-digit or four-digit number printed on the front or back of a payment card (“card verification code”), mark this requirement as Not Applicable and complete Appendix C: Explanation of Requirements Noted as Not Applicable.						

PCI DSS Requirement		Expected Testing	Response* (Check one response for each requirement)			
			In Place	In Place with CCW	Not Applicable	Not in Place
3.3.1.3	The personal identification number (PIN) and the PIN block are not stored upon completion of the authorization process.	Examine data sources.	☐	☐	☒	☐
	Applicability Notes PIN blocks are encrypted during the natural course of transaction processes, but even if an entity encrypts the PIN block again, it is still not allowed to be stored after the completion of the authorization process.					

Requirement 4: Protect Cardholder Data with Strong Cryptography During Transmission Over Open, Public Networks

Note: For SAQ A-EP, Requirement 4 applies to merchants when sending payment related data to their TPSP.

PCI DSS Requirement		Expected Testing	Response*			
			(Check one response for each requirement)			
			In Place	In Place with CCW	Not Applicable	Not in Place
4.1 Processes and mechanisms for protecting cardholder data with strong cryptography during transmission over open, public networks are defined and understood.						
4.1.1	All security policies and operational procedures that are identified in Requirement 4 are: - Documented. - Kept up to date. - In use. - Known to all affected parties.	- Examine documentation. - Interview personnel.	☒	☐	☐	☐

SAQ Completion Guidance:
 Selection of any of the *In Place* responses for Requirement 4.1.1 means that the merchant has policies and procedures in place that govern merchant activities for Requirement 4.

* Refer to the "Requirement Responses" section (page v) for information about these response options.

PCI DSS Requirement		Expected Testing	Response*			
			(Check one response for each requirement)			
			In Place	In Place with CCW	Not Applicable	Not in Place
4.2 PAN is protected with strong cryptography during transmission.						
4.2.1	Strong cryptography and security protocols are implemented as follows to safeguard PAN during transmission over open, public networks:					
	Only trusted keys and certificates are accepted.	- Examine documented policies and procedures. - Interview personnel. - Examine system configurations. - Examine cardholder data transmissions. - Examine keys and certificates.	☐	☐	☒	☐
	Certificates used to safeguard PAN during transmission over open, public networks are confirmed as valid and are not expired or revoked. <i>This bullet is a best practice until its effective date; refer to Applicability Notes below for details.</i>		☐	☐	☒	☐
	The protocol in use supports only secure versions or configurations and does not support fallback to, or use of insecure versions, algorithms, key sizes, or implementations.		☐	☐	☒	☐
	The encryption strength is appropriate for the encryption methodology in use.		☐	☐	☒	☐
Applicability Notes						
A self-signed certificate may also be acceptable if the certificate is issued by an internal CA within the organization, the certificate's author is confirmed, and the certificate is verified—for example, via hash or signature—and has not expired. <i>The bullet above (for confirming that certificates used to safeguard PAN during transmission over open, public networks are valid and are not expired or revoked) is a best practice until 31 March 2025, after which it will be required as part of Requirement 4.2.1 and must be fully considered during a PCI DSS assessment.</i>						

PCI DSS Requirement		Expected Testing	Response* (Check one response for each requirement)			
			In Place	In Place with CCW	Not Applicable	Not in Place
4.2.2	PAN is secured with strong cryptography whenever it is sent via end-user messaging technologies.	- Examine documented policies and procedures. - Examine system configurations and vendor documentation.	☐	☐	☒	☐
	Applicability Notes This requirement also applies if a customer, or other third-party, requests that PAN is sent to them via end-user messaging technologies. There could be occurrences where an entity receives unsolicited cardholder data via an insecure communication channel that was not intended for transmissions of sensitive data. In this situation, the entity can choose to either include the channel in the scope of their CDE and secure it according to PCI DSS or delete the cardholder data and implement measures to prevent the channel from being used for cardholder data.					

Maintain a Vulnerability Management Program

Requirement 5: Protect All Systems and Networks from Malicious Software

PCI DSS Requirement		Expected Testing	Response* (Check one response for each requirement)			
			In Place	In Place with CCW	Not Applicable	Not in Place
5.1 Processes and mechanisms for protecting all systems and networks from malicious software are defined and understood.						
5.1.1	All security policies and operational procedures that are identified in Requirement 5 are: • Documented. • Kept up to date. • In use. • Known to all affected parties.	• Examine documentation. • Interview personnel.	☒	☐	☐	☐
SAQ Completion Guidance: <i>Selection of any of the In Place responses for Requirement 5.1.1 means that the merchant has policies and procedures in place that govern merchant activities for Requirement 5.</i>						
5.2 Malicious software (malware) is prevented, or detected and addressed.						
5.2.1	An anti-malware solution(s) is deployed on all system components, except for those system components identified in periodic evaluations per Requirement 5.2.3 that concludes the system components are not at risk from malware.	• Examine system components. • Examine the periodic evaluations.	☒	☐	☐	☐
5.2.2	The deployed anti-malware solution(s): • Detects all known types of malware. • Removes, blocks, or contains all known types of malware.	• Examine vendor documentation. • Examine system configurations.	☐	☐	☒	☐

* Refer to the "Requirement Responses" section (page v) for information about these response options.

PCI DSS Requirement		Expected Testing	Response* (Check one response for each requirement)			
			In Place	In Place with CCW	Not Applicable	Not in Place
5.2.3	Any system components that are not at risk for malware are evaluated periodically to include the following: - A documented list of all system components not at risk for malware. - Identification and evaluation of evolving malware threats for those system components. - Confirmation whether such system components continue to not require anti-malware protection.	- Examine documented policies and procedures. - Interview personnel. - Examine the list of system components not at risk for malware and compare against the system components without an anti-malware solution deployed.	☒	☐	☐	☐
	Applicability Notes					
	System components covered by this requirement are those for which there is no anti-malware solution deployed per Requirement 5.2.1.					
5.2.3.1	The frequency of periodic evaluations of system components identified as not at risk for malware is defined in the entity's targeted risk analysis, which is performed according to all elements specified in Requirement 12.3.1.	- Examine the targeted risk analysis. - Examine documented results of periodic evaluations. - Interview personnel.	☒	☐	☐	☐
	Applicability Notes					
	This requirement is a best practice until 31 March 2025, after which it will be required and must be fully considered during a PCI DSS assessment.					
5.3 Anti-malware mechanisms and processes are active, maintained, and monitored.						
5.3.1	The anti-malware solution(s) is kept current via automatic updates.	- Examine anti-malware solution(s) configurations, including any master installation. - Examine system components and logs.	☐	☐	☒	☐

PCI DSS Requirement		Expected Testing	Response* (Check one response for each requirement)			
			In Place	In Place with CCW	Not Applicable	Not in Place
5.3.2	The anti-malware solution(s): - Performs periodic scans and active or real-time scans OR - Performs continuous behavioral analysis of systems or processes.	- Examine anti-malware solution(s) configurations, including any master installation. - Examine system components. - Examine logs and scan results.	☐	☐	☒	☐
5.3.2.1	If periodic malware scans are performed to meet Requirement 5.3.2, the frequency of scans is defined in the entity's targeted risk analysis, which is performed according to all elements specified in Requirement 12.3.1.	- Examine the targeted risk analysis. - Examine documented results of periodic malware scans. - Interview personnel.	☐	☐	☒	☐
Applicability Notes						
This requirement applies to entities conducting periodic malware scans to meet Requirement 5.3.2. <i>This requirement is a best practice until 31 March 2025, after which it will be required and must be fully considered during a PCI DSS assessment.</i>						
5.3.3	For removable electronic media, the anti-malware solution(s): - Performs automatic scans of when the media is inserted, connected, or logically mounted, OR - Performs continuous behavioral analysis of systems or processes when the media is inserted, connected, or logically mounted.	- Examine anti-malware solution(s) configurations. - Examine system components with removable electronic media. - Examine logs and scan results.	☐	☐	☒	☐
Applicability Notes						
<i>This requirement is a best practice until 31 March 2025, after which it will be required and must be fully considered during a PCI DSS assessment.</i>						

PCI DSS Requirement		Expected Testing	Response* (Check one response for each requirement)			
			In Place	In Place with CCW	Not Applicable	Not in Place
5.3.4	Audit logs for the anti-malware solution(s) are enabled and retained in accordance with Requirement 10.5.1.	Examine anti-malware solution(s) configurations.	☐	☐	☒	☐
5.3.5	Anti-malware mechanisms cannot be disabled or altered by users, unless specifically documented, and authorized by management on a case-by-case basis for a limited time period.	- Examine anti-malware configurations. - Observe processes. - Interview responsible personnel.	☐	☐	☒	☐
Applicability Notes Anti-malware solutions may be temporarily disabled only if there is a legitimate technical need, as authorized by management on a case-by-case basis. If anti-malware protection needs to be disabled for a specific purpose, it must be formally authorized. Additional security measures may also need to be implemented for the period during which anti-malware protection is not active.						
5.4 Anti-phishing mechanisms protect users against phishing attacks.						
5.4.1	Processes and automated mechanisms are in place to detect and protect personnel against phishing attacks.	- Observe implemented processes. - Examine mechanisms.	☒	☐	☐	☐
Applicability Notes The focus of this requirement is on protecting personnel with access to system components in-scope for PCI DSS. Meeting this requirement for technical and automated controls to detect and protect personnel against phishing is not the same as Requirement 12.6.3.1 for security awareness training. Meeting this requirement does not also meet the requirement for providing personnel with security awareness training, and vice versa. <i>This requirement is a best practice until 31 March 2025, after which it will be required and must be fully considered during a PCI DSS assessment.</i>						

Requirement 6: Develop and Maintain Secure Systems and Software

Note: For SAQ A-EP, Requirement 6 applies to merchant server(s) that host the payment page(s) provided from the merchant's website to the customer's browser.

PCI DSS Requirement		Expected Testing	Response* (Check one response for each requirement)			
			In Place	In Place with CCW	Not Applicable	Not in Place
6.1 Processes and mechanisms for developing and maintaining secure systems and software are defined and understood.						
6.1.1	All security policies and operational procedures that are identified in Requirement 6 are: - Documented. - Kept up to date. - In use. - Known to all affected parties.	- Examine documentation. - Interview personnel.	☒	☐	☐	☐
SAQ Completion Guidance: Selection of any of the In Place responses for Requirement 6.1.1 means that the merchant has policies and procedures in place that govern merchant activities for Requirement 6.						
6.2 Bespoke and custom software are developed securely.						
Note: For SAQ A-EP, requirements at 6.2 apply to merchants with bespoke software (developed to the entity's specifications by a third party) or custom software (developed by the entity). If merchant does not have such software, mark these requirements as Not Applicable and complete Appendix C: Explanation of Requirements Noted as Not Applicable.						
6.2.1	Bespoke and custom software are developed securely, as follows: - Based on industry standards and/or best practices for secure development. <i>Bullet intentionally left blank for this SAQ.</i> <i>Bullet intentionally left blank for this SAQ.</i>	Examine documented software development procedures.	☒	☐	☐	☐
Applicability Notes			☒	☐	☐	☐
This applies to all software developed for or by the entity for the entity's own use. This includes both bespoke and custom software. This does not apply to third-party software.						

* Refer to the "Requirement Responses" section (page v) for information about these response options.

PCI DSS Requirement		Expected Testing	Response* (Check one response for each requirement)			
			In Place	In Place with CCW	Not Applicable	Not in Place
6.2.2	Software development personnel working on bespoke and custom software are trained at least once every 12 months as follows: - On software security relevant to their job function and development languages. - Including secure software design and secure coding techniques. - Including, if security testing tools are used, how to use the tools for detecting vulnerabilities in software.	- Examine documented software development procedures. - Examine training records. - Interview personnel.	☒	☐	☐	☐
6.2.4	Software engineering techniques or other methods are defined and in use by software development personnel to prevent or mitigate common software attacks and related vulnerabilities in bespoke and custom software, including but not limited to the following: - Injection attacks, including SQL, LDAP, XPath, or other command, parameter, object, fault, or injection-type flaws. - Attacks on data and data structures, including attempts to manipulate buffers, pointers, input data, or shared data. - Attacks on cryptography usage, including attempts to exploit weak, insecure, or inappropriate cryptographic implementations, algorithms, cipher suites, or modes of operation. - Attacks on business logic, including attempts to abuse or bypass application features and functionalities through the manipulation of APIs, communication protocols and channels, client-side functionality, or other system/application functions and resources. This includes cross-site scripting (XSS) and cross-site request forgery (CSRF).	- Examine documented procedures. - Interview responsible software development personnel.	☒	☐	☐	☐
			☒	☐	☐	☐
			☒	☐	☐	☐
			☒	☐	☐	☐

PCI DSS Requirement		Expected Testing	Response* (Check one response for each requirement)			
			In Place	In Place with CCW	Not Applicable	Not in Place
6.2.4 (cont.)	Attacks on access control mechanisms, including attempts to bypass or abuse identification, authentication, or authorization mechanisms, or attempts to exploit weaknesses in the implementation of such mechanisms.		☒	☐	☐	☐
	Attacks via any "high-risk" vulnerabilities identified in the vulnerability identification process, as defined in Requirement 6.3.1.		☒	☐	☐	☐
	Applicability Notes This applies to all software developed for or by the entity for the entity's own use. This includes both bespoke and custom software. This does not apply to third-party software.					
6.3 Security vulnerabilities are identified and addressed.						
6.3.1	Security vulnerabilities are identified and managed as follows: - New security vulnerabilities are identified using industry-recognized sources for security vulnerability information, including alerts from international and national computer emergency response teams (CERTs). - Vulnerabilities are assigned a risk ranking based on industry best practices and consideration of potential impact. - Risk rankings identify, at a minimum, all vulnerabilities considered to be a high-risk or critical to the environment. - Vulnerabilities for bespoke and custom, and third-party software (for example operating systems and databases) are covered.	- Examine policies and procedures. - Interview responsible personnel. - Examine documentation. - Observe processes.	☒	☐	☐	☐
	Applicability Notes (continued)					

PCI DSS Requirement		Expected Testing	Response* (Check one response for each requirement)			
			In Place	In Place with CCW	Not Applicable	Not in Place
	This requirement is not achieved by, and is in addition to, performing vulnerability scans according to Requirements 11.3.1 and 11.3.2. This requirement is for a process to actively monitor industry sources for vulnerability information and for the entity to determine the risk ranking to be associated with each vulnerability.					
6.3.2	An inventory of bespoke and custom software, and third-party software components incorporated into bespoke and custom software is maintained to facilitate vulnerability and patch management.	- Examine documentation. - Interview personnel.	☒	☐	☐	☐
Applicability Notes						
<i>This requirement is a best practice until 31 March 2025, after which it will be required and must be fully considered during a PCI DSS assessment.</i>						
6.3.3	All system components are protected from known vulnerabilities by installing applicable security patches/updates as follows: - Patches/updates for critical vulnerabilities (identified according to the risk ranking process at Requirement 6.3.1) are installed within one month of release. <i>Bullet intentionally left blank for this SAQ.</i>	- Examine policies and procedures. - Examine system components and related software. - Compare list of security patches installed to recent vendor patch lists.	☒	☐	☐	☐

PCI DSS Requirement	Expected Testing	Response* (Check one response for each requirement)				
		In Place	In Place with CCW	Not Applicable	Not in Place	
6.4 Public-facing web applications are protected against attacks.						
6.4.1	For public-facing web applications, new threats and vulnerabilities are addressed on an ongoing basis and these applications are protected against known attacks as follows: - Reviewing public-facing web applications via manual or automated application vulnerability security assessment tools or methods as follows: - At least once every 12 months and after significant changes. - By an entity that specializes in application security. - Including, at a minimum, all common software attacks in Requirement 6.2.4. - All vulnerabilities are ranked in accordance with Requirement 6.3.1. - All vulnerabilities are corrected. - The application is re-evaluated after the corrections. OR - Installing an automated technical solution(s) that continually detects and prevents web-based attacks as follows: - Installed in front of public-facing web applications to detect and prevent web-based attacks. - Actively running and up to date as applicable. - Generating audit logs. - Configured to either block web-based attacks or generate an alert that is immediately investigated.	- Examine documented processes. - Interview personnel. - Examine records of application security assessments. - Examine the system configuration settings and audit logs.	☐	☒	☐	☐
Applicability Notes (continued)						

PCI DSS Requirement	Expected Testing	Response* (Check one response for each requirement)			
		In Place	In Place with CCW	Not Applicable	Not in Place
6.4.1 <i>(cont.)</i> This assessment is not the same as the vulnerability scans performed for Requirement 11.3.1 and 11.3.2. This requirement will be superseded by Requirement 6.4.2 after 31 March 2025 when Requirement 6.4.2 becomes effective.					
6.4.2 For public-facing web applications, an automated technical solution is deployed that continually detects and prevents web-based attacks, with at least the following: - Is installed in front of public-facing web applications and is configured to detect and prevent web-based attacks. - Actively running and up to date as applicable. - Generating audit logs. - Configured to either block web-based attacks or generate an alert that is immediately investigated.	- Examine the system configuration settings. - Examine audit logs. - Interview responsible personnel.	☐	☒	☐	☐
Applicability Notes This new requirement will replace Requirement 6.4.1 once its effective date is reached. <i>This requirement is a best practice until 31 March 2025, after which it will be required and must be fully considered during a PCI DSS assessment.</i>					

PCI DSS Requirement	Expected Testing	Response* (Check one response for each requirement)			
		In Place	In Place with CCW	Not Applicable	Not in Place
Note: For SAQ A-EP, Requirement 6.4.3 applies to any scripts on the payment page(s) provided from the merchant's website to the customer's browser.					
6.4.3	All payment page scripts that are loaded and executed in the consumer's browser are managed as follows:				
A method is implemented to confirm that each script is authorized.	- Examine policies and procedures. - Interview responsible personnel.	☒	☐	☐	☐
A method is implemented to assure the integrity of each script.	- Examine inventory records. - Examine system configurations.	☒	☐	☐	☐
An inventory of all scripts is maintained with written business or technical justification as to why each is necessary.		☒	☐	☐	☐
Applicability Notes					
This requirement applies to all scripts loaded from the entity's environment and scripts loaded from third and fourth parties. This requirement also applies to scripts in the entity's webpage(s) that includes a TPSP's/ payment processor's embedded payment page/form (for example, one or more inline frames or iframes). This requirement does not apply to an entity for scripts in a TPSP's/payment processor's embedded payment page/form (for example, one or more iframes), where the entity includes a TPSP's/payment processor's payment page/form on its webpage. Scripts in the TPSP's/payment processor's embedded payment page/form are the responsibility of the TPSP/payment processor to manage in accordance with this requirement. <i>This requirement is a best practice until 31 March 2025, after which it will be required and must be fully considered during a PCI DSS assessment.</i>					
SAQ Completion Guidance: Where the merchant server redirects customers from the merchant website to a TPSP/payment processor (for example, with a URL redirect), the merchant marks this requirement as Not Applicable and completes Appendix C: Explanation of Requirements Noted as Not Applicable.					

PCI DSS Requirement		Expected Testing	Response* (Check one response for each requirement)			
			In Place	In Place with CCW	Not Applicable	Not in Place
6.5 Changes to all system components are managed securely.						
6.5.1	Changes to all system components in the production environment are made according to established procedures that include: - Reason for, and description of, the change. - Documentation of security impact. - Documented change approval by authorized parties. - Testing to verify that the change does not adversely impact system security. - For bespoke and custom software changes, all updates are tested for compliance with Requirement 6.2.4 before being deployed into production. - Procedures to address failures and return to a secure state.	- Examine documented change control procedures. - Examine recent changes to system components and trace changes to change control documentation. - Examine change control documentation.	☒	☐	☐	☐
6.5.2	Upon completion of a significant change, all applicable PCI DSS requirements are confirmed to be in place on all new or changed systems and networks, and documentation is updated as applicable.	- Examine documentation for significant changes. - Interview personnel. - Observe the affected systems/networks.	☒	☐	☐	☐
Applicability Notes			☒	☐	☐	☐
This Applicability Note was intentionally removed as it does not apply to this SAQ.						

Implement Strong Access Control Measures

Requirement 7: Restrict Access to System Components and Cardholder Data by Business Need to Know

PCI DSS Requirement		Expected Testing	Response* (Check one response for each requirement)			
			In Place	In Place with CCW	Not Applicable	Not in Place
7.2 Access to system components and data is appropriately defined and assigned.						
7.2.2	Access is assigned to users, including privileged users, based on: - Job classification and function. - Least privileges necessary to perform job responsibilities.	- Examine policies and procedures. - Examine user access settings, including for privileged users. - Interview responsible management personnel. - Interview personnel responsible for assigning access.	☒	☐	☐	☐
7.2.3	Required privileges are approved by authorized personnel.	- Examine policies and procedures. - Examine user IDs and assigned privileges. - Examine documented approvals.	☒	☐	☐	☐

* Refer to the "Requirement Responses" section (page v) for information about these response options.

PCI DSS Requirement		Expected Testing	Response* (Check one response for each requirement)			
			In Place	In Place with CCW	Not Applicable	Not in Place
7.2.4	All user accounts and related access privileges, including third-party/vendor accounts, are reviewed as follows: - At least once every six months. - To ensure user accounts and access remain appropriate based on job function. - Any inappropriate access is addressed. - Management acknowledges that access remains appropriate.	- Examine policies and procedures. - Interview responsible personnel. - Examine documented results of periodic reviews of user accounts.	☒	☐	☐	☐
Applicability Notes						
This requirement applies to all user accounts and related access privileges, including those used by personnel and third parties/vendors, and accounts used to access third-party cloud services. See Requirements 7.2.5 and 7.2.5.1 and 8.6.1 through 8.6.3 for controls for application and system accounts. <i>This requirement is a best practice until 31 March 2025, after which it will be required and must be fully considered during a PCI DSS assessment.</i>						
7.2.5	All application and system accounts and related access privileges are assigned and managed as follows: - Based on the least privileges necessary for the operability of the system or application. - Access is limited to the systems, applications, or processes that specifically require their use.	- Examine policies and procedures. - Examine privileges associated with system and application accounts. - Interview responsible personnel.	☒	☐	☐	☐
Applicability Notes						
<i>This requirement is a best practice until 31 March 2025, after which it will be required and must be fully considered during a PCI DSS assessment.</i>						

Requirement 8: Identify Users and Authenticate Access to System Components

Note: For SAQ A-EP, Requirement 8 applies to merchant servers that host the payment page(s) provided from the merchant's website to the customer's browser.

PCI DSS Requirement		Expected Testing	Response* (Check one response for each requirement)			
			In Place	In Place with CCW	Not Applicable	Not in Place
8.1 Processes and mechanisms for identifying users and authenticating access to system components are defined and understood.						
8.1.1	All security policies and operational procedures that are identified in Requirement 8 are: - Documented. - Kept up to date. - In use. - Known to all affected parties.	- Examine documentation. - Interview personnel.	☒	☐	☐	☐
SAQ Completion Guidance: <i>Selection of any of the In Place responses for Requirement 8.1.1 means that the merchant has policies and procedures in place that govern merchant activities for Requirement 8.</i>						
8.2 User identification and related accounts for users and administrators are strictly managed throughout an account’s lifecycle.						
8.2.1	All users are assigned a unique ID before access to system components or cardholder data is allowed.	- Interview responsible personnel. - Examine audit logs and other evidence.	☒	☐	☐	☐
Applicability Notes						
This requirement is not intended to apply to user accounts within point-of-sale terminals that have access to only one card number at a time to facilitate a single transaction.						

* Refer to the "Requirement Responses" section (page v) for information about these response options.

PCI DSS Requirement		Expected Testing	Response* (Check one response for each requirement)			
			In Place	In Place with CCW	Not Applicable	Not in Place
8.2.2	Group, shared, or generic IDs, or other shared authentication credentials are only used when necessary on an exception basis, and are managed as follows: - ID use is prevented unless needed for an exceptional circumstance. - Use is limited to the time needed for the exceptional circumstance. - Business justification for use is documented. - Use is explicitly approved by management. - Individual user identity is confirmed before access to an account is granted. - Every action taken is attributable to an individual user.	- Examine user account lists on system components and applicable documentation. - Examine authentication policies and procedures. - Interview system administrators.	☒	☐	☐	☐
	Applicability Notes					
	This requirement is not intended to apply to user accounts within point-of-sale terminals that have access to only one card number at a time to facilitate a single transaction.					
8.2.4	Addition, deletion, and modification of user IDs, authentication factors, and other identifier objects are managed as follows: - Authorized with the appropriate approval. - Implemented with only the privileges specified on the documented approval.	- Examine documented authorizations across various phases of the account lifecycle (additions, modifications, and deletions). - Examine system settings.	☒	☐	☐	☐
	Applicability Notes					
	This requirement applies to all user accounts, including employees, contractors, consultants, temporary workers, and third-party vendors.					

PCI DSS Requirement		Expected Testing	Response* (Check one response for each requirement)			
			In Place	In Place with CCW	Not Applicable	Not in Place
8.2.5	Access for terminated users is immediately revoked.	- Examine information sources for terminated users. - Review current user access lists. - Interview responsible personnel.	☒	☐	☐	☐
8.2.6	Inactive user accounts are removed or disabled within 90 days of inactivity.	- Examine user accounts and last logon information. - Interview responsible personnel.	☒	☐	☐	☐
8.2.7	Accounts used by third parties to access, support, or maintain system components via remote access are managed as follows: - Enabled only during the time period needed and disabled when not in use. - Use is monitored for unexpected activity.	- Interview responsible personnel. - Examine documentation for managing accounts. - Examine evidence.	☒	☐	☐	☐
8.2.8	If a user session has been idle for more than 15 minutes, the user is required to re-authenticate to re-activate the terminal or session.	Examine system configuration settings.	☒	☐	☐	☐
Applicability Notes						
This requirement is not intended to apply to user accounts on point-of-sale terminals that have access to only one card number at a time to facilitate a single transaction.						
This requirement is not meant to prevent legitimate activities from being performed while the console/PC is unattended.						

PCI DSS Requirement		Expected Testing	Response* (Check one response for each requirement)			
			In Place	In Place with CCW	Not Applicable	Not in Place
8.3 Strong authentication for users and administrators is established and managed.						
8.3.1	All user access to system components for users and administrators is authenticated via at least one of the following authentication factors: - Something you know, such as a password or passphrase. - Something you have, such as a token device or smart card. - Something you are, such as a biometric element.	- Examine documentation describing the authentication factor(s) used. - For each type of authentication factor used with each type of system component, observe the authentication process.	☒	☐	☐	☐
Applicability Notes						
This requirement is not intended to apply to user accounts on point-of-sale terminals that have access to only one card number at a time to facilitate a single transaction. This requirement does not supersede multi-factor authentication (MFA) requirements but applies to those in-scope systems not otherwise subject to MFA requirements. A digital certificate is a valid option for “something you have” if it is unique for a particular user.						
8.3.2	Strong cryptography is used to render all authentication factors unreadable during transmission and storage on all system components.	- Examine vendor documentation. - Examine system configuration settings. - Examine repositories of authentication factors. - Examine data transmissions.	☒	☐	☐	☐
8.3.3	User identity is verified before modifying any authentication factor.	- Examine procedures for modifying authentication factors. - Observe security personnel.	☒	☐	☐	☐

PCI DSS Requirement		Expected Testing	Response* (Check one response for each requirement)				
			In Place	In Place with CCW	Not Applicable	Not in Place	
8.3.4	Invalid authentication attempts are limited by: • Locking out the user ID after not more than 10 attempts. • Setting the lockout duration to a minimum of 30 minutes or until the user's identity is confirmed.	• Examine system configuration settings.	☒	☐	☐	☐	
	Applicability Notes						
	This requirement is not intended to apply to user accounts within point-of-sale terminals that have access to only one card number at a time to facilitate a single transaction.						
8.3.5	If passwords/passphrases are used as authentication factors to meet Requirement 8.3.1, they are set and reset for each user as follows: • Set to a unique value for first-time use and upon reset. • Forced to be changed immediately after the first use.	• Examine procedures for setting and resetting passwords/passphrases. • Observe security personnel.	☒	☐	☐	☐	
8.3.6	If passwords/passphrases are used as authentication factors to meet Requirement 8.3.1, they meet the following minimum level of complexity: • A minimum length of 12 characters (or IF the system does not support 12 characters, a minimum length of eight characters). • Contain both numeric and alphabetic characters.	• Examine system configuration settings.	☒	☐	☐	☐	
	Applicability Notes						
	This requirement is not intended to apply to: • User accounts on point-of-sale terminals that have access to only one card number at a time to facilitate a single transaction. • Application or system accounts, which are governed by requirements in section 8.6. <i>This requirement is a best practice until 31 March 2025, after which it will be required and must be fully considered during a PCI DSS assessment.</i> Until 31 March 2025, passwords must be a minimum length of seven characters in accordance with PCI DSS v3.2.1 Requirement 8.2.3.						

PCI DSS Requirement		Expected Testing	Response* (Check one response for each requirement)			
			In Place	In Place with CCW	Not Applicable	Not in Place
8.3.7	Individuals are not allowed to submit a new password/passphrase that is the same as any of the last four passwords/passphrases used.	Examine system configuration settings.	☒	☐	☐	☐
	Applicability Notes This requirement is not intended to apply to user accounts within point-of-sale terminals that have access to only one card number at a time to facilitate a single transaction.					
8.3.8	Authentication policies and procedures are documented and communicated to all users including: - Guidance on selecting strong authentication factors. - Guidance for how users should protect their authentication factors. - Instructions not to reuse previously used passwords/passphrases. - Instructions to change passwords/passphrases if there is any suspicion or knowledge that the password/passphrases have been compromised and how to report the incident.	- Examine procedures. - Interview personnel. - Review authentication policies and procedures that are distributed to users. - Interview users.	☒	☐	☐	☐
8.3.9	If passwords/passphrases are used as the only authentication factor for user access (i.e., in any single-factor authentication implementation) then either: - Passwords/passphrases are changed at least once every 90 days, OR - The security posture of accounts is dynamically analyzed, and real-time access to resources is automatically determined accordingly.	Inspect system configuration settings.	☒	☐	☐	☐
Applicability Notes (continued)						

PCI DSS Requirement		Expected Testing	Response* (Check one response for each requirement)			
			In Place	In Place with CCW	Not Applicable	Not in Place
8.3.9 (cont.)	This requirement does not apply to in-scope system components where MFA is used. This requirement is not intended to apply to user accounts on point-of-sale terminals that have access to only one card number at a time to facilitate a single transaction. This requirement does not apply to service providers' customer accounts but does apply to accounts for service provider personnel.					
8.3.11	Where authentication factors such as physical or logical security tokens, smart cards, or certificates are used: - Factors are assigned to an individual user and not shared among multiple users. - Physical and/or logical controls ensure only the intended user can use that factor to gain access.	- Examine authentication policies and procedures. - Interview security personnel. - Examine system configuration settings and/or observe physical controls, as applicable.	☒	☐	☐	☐
8.4 Multi-factor authentication (MFA) is implemented to secure access into the CDE.						
8.4.1	MFA is implemented for all non-console access into the CDE for personnel with administrative access.	- Examine network and/or system configurations. - Observe administrator personnel logging into the CDE.	☒	☐	☐	☐
Applicability Notes						
The requirement for MFA for non-console administrative access applies to all personnel with elevated or increased privileges accessing the CDE via a non-console connection—that is, via logical access occurring over a network interface rather than via a direct, physical connection.						

PCI DSS Requirement		Expected Testing	Response* (Check one response for each requirement)			
			In Place	In Place with CCW	Not Applicable	Not in Place
8.4.2	MFA is implemented for all non-console access into the CDE.	- Examine network and/or system configurations. - Observe personnel logging in to the CDE. - Examine evidence.	☒	☐	☐	☐
Applicability Notes						
This requirement does not apply to: - Application or system accounts performing automated functions. - User accounts on point-of-sale terminals that have access to only one card number at a time to facilitate a single transaction. - User accounts that are only authenticated with phishing-resistant authentication factors. MFA is required for both types of access specified in Requirements 8.4.2 and 8.4.3. Therefore, applying MFA to one type of access does not replace the need to apply another instance of MFA to the other type of access. If an individual first connects to the entity's network via remote access, and then later initiates a connection into the CDE from within the network, per this requirement the individual would authenticate using MFA twice, once when connecting via remote access to the entity's network and once when connecting from the entity's network into the CDE. The MFA requirements apply for all types of system components, including cloud, hosted systems, and on-premises applications, network security devices, workstations, servers, and endpoints, and includes access directly to an entity's networks or systems as well as web-based access to an application or function. MFA for access into the CDE can be implemented at the network or system/application level; it does not have to be applied at both levels. For example, if MFA is used when a user connects to the CDE network, it does not have to be used when the user logs into each system or application within the CDE. <i>This requirement is a best practice until 31 March 2025, after which it will be required and must be fully considered during a PCI DSS assessment.</i>						

PCI DSS Requirement		Expected Testing	Response* (Check one response for each requirement)			
			In Place	In Place with CCW	Not Applicable	Not in Place
8.4.3	MFA is implemented for all remote access originating from outside the entity's network that could access or impact the CDE.	- Examine network and/or system configurations for remote access servers and systems. - Observe personnel (for example, users and administrators) and third parties connecting remotely to the network.	☒	☐	☐	☐
	Applicability Notes The requirement for MFA for remote access originating from outside the entity's network applies to all user accounts that can access the network remotely, where that remote access leads to or could lead to access into the CDE. This includes all remote access by personnel (users and administrators), and third parties (including, but not limited to, vendors, suppliers, service providers, and customers). If remote access is to a part of the entity's network that is properly segmented from the CDE, such that remote users cannot access or impact the CDE, MFA for remote access to that part of the network is not required. However, MFA is required for any remote access to networks with access to the CDE and is recommended for all remote access to the entity's networks. The MFA requirements apply for all types of system components, including cloud, hosted systems, and on-premises applications, network security devices, workstations, servers, and endpoints, and includes access directly to an entity's networks or systems as well as web-based access to an application or function.					

PCI DSS Requirement		Expected Testing	Response* (Check one response for each requirement)			
			In Place	In Place with CCW	Not Applicable	Not in Place
8.5 Multi-factor authentication (MFA) systems are configured to prevent misuse.						
8.5.1	MFA systems are implemented as follows: - The MFA system is not susceptible to replay attacks. - MFA systems cannot be bypassed by any users, including administrative users unless specifically documented, and authorized by management on an exception basis, for a limited time period. - At least two different types of authentication factors are used. - Success of all authentication factors is required before access is granted.	- Examine vendor system documentation. - Examine system configurations for the MFA implementation. - Interview responsible personnel and observe processes. - Observe personnel logging into system components in the CDE. - Observe personnel connecting remotely from outside the entity's network.	☒	☐	☐	☐
Applicability Notes						
This requirement is a best practice until 31 March 2025, after which it will be required and must be fully considered during a PCI DSS assessment.						

PCI DSS Requirement		Expected Testing	Response* (Check one response for each requirement)			
			In Place	In Place with CCW	Not Applicable	Not in Place
8.6 Use of application and system accounts and associated authentication factors is strictly managed.						
8.6.1	If accounts used by systems or applications can be used for interactive login, they are managed as follows: • Interactive use is prevented unless needed for an exceptional circumstance. • Interactive use is limited to the time needed for the exceptional circumstance. • Business justification for interactive use is documented. • Interactive use is explicitly approved by management. • Individual user identity is confirmed before access to account is granted. • Every action taken is attributable to an individual user.	• Examine application and system accounts that can be used interactively. • Interview administrative personnel.	☒	☐	☐	☐
Applicability Notes			☒	☐	☐	☐
This requirement is a best practice until 31 March 2025, after which it will be required and must be fully considered during a PCI DSS assessment.						

PCI DSS Requirement		Expected Testing	Response* (Check one response for each requirement)			
			In Place	In Place with CCW	Not Applicable	Not in Place
8.6.2	Passwords/passphrases for any application and system accounts that can be used for interactive login are not hard coded in scripts, configuration/property files, or bespoke and custom source code.	- Interview personnel. - Examine system development procedures. - Examine scripts, configuration/property files, and bespoke and custom source code for application and system accounts that can be used for interactive login.	☒	☐	☐	☐
	Applicability Notes					
	Stored passwords/passphrases are required to be encrypted in accordance with PCI DSS Requirement 8.3.2. <i>This requirement is a best practice until 31 March 2025, after which it will be required and must be fully considered during a PCI DSS assessment.</i>					
8.6.3	Passwords/passphrases for any application and system accounts are protected against misuse as follows: - Passwords/passphrases are changed periodically (at the frequency defined in the entity's targeted risk analysis, which is performed according to all elements specified in Requirement 12.3.1) and upon suspicion or confirmation of compromise. - Passwords/passphrases are constructed with sufficient complexity appropriate for how frequently the entity changes the passwords/passphrases.	- Examine policies and procedures. - Examine the targeted risk analysis. - Interview responsible personnel. - Examine system configuration settings.	☒	☐	☐	☐
	Applicability Notes					
	<i>This requirement is a best practice until 31 March 2025, after which it will be required and must be fully considered during a PCI DSS assessment.</i>					

Requirement 9: Restrict Physical Access to Cardholder Data

PCI DSS Requirement		Expected Testing	Response* (Check one response for each requirement)			
			In Place	In Place with CCW	Not Applicable	Not in Place
9.2 Physical access controls manage entry into facilities and systems containing cardholder data.						
9.2.1	Appropriate facility entry controls are in place to restrict physical access to systems in the CDE.	- Observe physical entry controls. - Interview responsible personnel.	☐	☐	☒	☐
	Applicability Notes					
	Part of this Applicability Note was intentionally removed as it does not apply to SAQ A-EP assessments.					
9.4 Media with cardholder data is securely stored, accessed, distributed, and destroyed.						
Note: For SAQ A-EP, Requirements at 9.4 only apply to merchants with paper records (for example, receipts or printed reports) with account data, including primary account numbers (PANs).						
9.4.1	All media with cardholder data is physically secured.	Examine documentation.	☐	☐	☒	☐
9.4.1.1	Offline media backups with cardholder data are stored in a secure location.	- Examine documented procedures. - Examine logs or other documentation. - Interview responsible personnel at the storage location(s).	☐	☐	☒	☐
9.4.2	All media with cardholder data is classified in accordance with the sensitivity of the data.	- Examine documented procedures. - Examine media logs or other documentation.	☐	☐	☒	☐
9.4.3	Media with cardholder data sent outside the facility is secured as follows: - Bullet intentionally left blank for this SAQ. - Media is sent by secured courier or other delivery method that can be accurately tracked. - Bullet intentionally left blank for this SAQ.	- Examine documented procedures. - Interview personnel. - Examine records. - Examine offsite tracking logs for all media.	☐	☐	☒	☐

* Refer to the "Requirement Responses" section (page v) for information about these response options.

PCI DSS Requirement		Expected Testing	Response* (Check one response for each requirement)			
			In Place	In Place with CCW	Not Applicable	Not in Place
9.4.4	Management approves all media with cardholder data that is moved outside the facility (including when media is distributed to individuals).	- Examine documented procedures. - Examine offsite media tracking logs. - Interview responsible personnel.	☐	☐	☒	☐
	Applicability Notes					
	Individuals approving media movements should have the appropriate level of management authority to grant this approval. However, it is not specifically required that such individuals have “manager” as part of their title.					
9.4.6	Hard-copy materials with cardholder data are destroyed when no longer needed for business or legal reasons, as follows: - Materials are cross-cut shredded, incinerated, or pulped so that cardholder data cannot be reconstructed. - Materials are stored in secure storage containers prior to destruction.	- Examine the media destruction policy. - Observe processes. - Interview personnel. - Observe storage containers.	☐	☐	☒	☐
	Applicability Notes					
	These requirements for media destruction when that media is no longer needed for business or legal reasons are separate and distinct from PCI DSS Requirement 3.2.1, which is for securely deleting cardholder data when no longer needed per the entity’s cardholder data retention policies.					

SAQ Completion Guidance:

Selection of any of the In Place responses for Requirements at 9.4 means that the merchant securely stores any paper media with account data, for example by storing the paper in a locked drawer, cabinet, or safe, and that the merchant destroys such paper when no longer needed for business purposes. This includes a written document or policy for employees, so they know how to secure paper with account data and how to destroy the paper when no longer needed.

If the merchant never stores any paper with account data, mark this requirement as Not Applicable and complete Appendix C: Explanation of Requirements Noted as Not Applicable.

Regularly Monitor and Test Networks

Requirement 10: Log and Monitor All Access to System Components and Cardholder Data

PCI DSS Requirement		Expected Testing	Response* (Check one response for each requirement)			
			In Place	In Place with CCW	Not Applicable	Not in Place
10.2 Audit logs are implemented to support the detection of anomalies and suspicious activity, and the forensic analysis of events.						
10.2.1	Audit logs are enabled and active for all system components and cardholder data.	- Interview the system administrator. - Examine system configurations.	☒	☐	☐	☐
10.2.1.1	Audit logs capture all individual user access to cardholder data.	- Examine audit log configurations. - Examine audit log data.	☐	☐	☒	☐
10.2.1.2	Audit logs capture all actions taken by any individual with administrative access, including any interactive use of application or system accounts.	- Examine audit log configurations. - Examine audit log data.	☒	☐	☐	☐
10.2.1.3	Audit logs capture all access to audit logs.	- Examine audit log configurations. - Examine audit log data.	☒	☐	☐	☐
10.2.1.4	Audit logs capture all invalid logical access attempts.	- Examine audit log configurations. - Examine audit log data.	☒	☐	☐	☐
10.2.1.5	Audit logs capture all changes to identification and authentication credentials including, but not limited to: - Creation of new accounts. - Elevation of privileges. - All changes, additions, or deletions to accounts with administrative access.	- Examine audit log configurations. - Examine audit log data.	☒	☐	☐	☐
10.2.1.6	Audit logs capture the following: - All initialization of new audit logs, and - All starting, stopping, or pausing of the existing audit logs.	- Examine audit log configurations. - Examine audit log data.	☒	☐	☐	☐

* Refer to the "Requirement Responses" section (page v) for information about these response options.

PCI DSS Requirement		Expected Testing	Response* (Check one response for each requirement)			
			In Place	In Place with CCW	Not Applicable	Not in Place
10.2.1.7	Audit logs capture all creation and deletion of system-level objects.	- Examine audit log configurations. - Examine audit log data.	☒	☐	☐	☐
10.2.2	Audit logs record the following details for each auditable event: - User identification. - Type of event. - Date and time. - Success and failure indication. - Origination of event. - Identity or name of affected data, system component, resource, or service (for example, name and protocol).	- Interview responsible personnel. - Examine audit log configurations. - Examine audit log data.	☒	☐	☐	☐
10.3 Audit logs are protected from destruction and unauthorized modifications.						
10.3.1	Read access to audit logs files is limited to those with a job-related need.	- Interview system administrators. - Examine system configurations and privileges.	☒	☐	☐	☐
10.3.2	Audit log files are protected to prevent modifications by individuals.	- Examine system configurations and privileges. - Interview system administrators.	☒	☐	☐	☐
10.3.3	Audit log files, including those for external-facing technologies, are promptly backed up to a secure, central, internal log server(s) or other media that is difficult to modify.	Examine backup configurations or log files.	☒	☐	☐	☐
10.3.4	File integrity monitoring or change-detection mechanisms is used on audit logs to ensure that existing log data cannot be changed without generating alerts.	- Examine system settings. - Examine monitored files. - Examine results from monitoring activities.	☒	☐	☐	☐

PCI DSS Requirement		Expected Testing	Response* (Check one response for each requirement)			
			In Place	In Place with CCW	Not Applicable	Not in Place
10.4 Audit logs are reviewed to identify anomalies or suspicious activity.						
10.4.1	The following audit logs are reviewed at least once daily: - All security events. - Logs of all system components that store, process, or transmit CHD and/or SAD. - Logs of all critical system components. - Logs of all servers and system components that perform security functions (for example, network security controls, intrusion-detection systems/intrusion-prevention systems (IDS/IPS), authentication servers).	- Examine security policies and procedures. - Observe processes. - Interview personnel.	☒	☐	☐	☐
10.4.1.1	Automated mechanisms are used to perform audit log reviews.	- Examine log review mechanisms. - Interview personnel.	☒	☐	☐	☐
	Applicability Notes					
	This requirement is a best practice until 31 March 2025, after which it will be required and must be fully considered during a PCI DSS assessment.					
10.4.2	Logs of all other system components (those not specified in Requirement 10.4.1) are reviewed periodically.	- Examine security policies and procedures. - Examine documented results of log reviews. - Interview personnel.	☒	☐	☐	☐
	Applicability Notes					
	This requirement is applicable to all other in-scope system components not included in Requirement 10.4.1.					

PCI DSS Requirement		Expected Testing	Response* (Check one response for each requirement)			
			In Place	In Place with CCW	Not Applicable	Not in Place
10.4.2.1	The frequency of periodic log reviews for all other system components (not defined in Requirement 10.4.1) is defined in the entity's targeted risk analysis, which is performed according to all elements specified in Requirement 12.3.1.	- Examine the targeted risk analysis. - Examine documented results of periodic log reviews. - Interview personnel.	☒	☐	☐	☐
	Applicability Notes					
	<i>This requirement is a best practice until 31 March 2025, after which it will be required and must be fully considered during a PCI DSS assessment.</i>					
10.4.3	Exceptions and anomalies identified during the review process are addressed.	- Examine security policies and procedures. - Observe processes. - Interview personnel.	☒	☐	☐	☐
10.5 Audit log history is retained and available for analysis.						
10.5.1	Retain audit log history for at least 12 months, with at least the most recent three months immediately available for analysis.	- Examine documented audit log retention policies and procedures. - Examine configurations of audit log history. - Examine audit logs. - Interview personnel. - Observe processes.	☒	☐	☐	☐
10.6 Time-synchronization mechanisms support consistent time settings across all systems.						
10.6.1	System clocks and time are synchronized using time-synchronization technology.	Examine system configuration settings.	☒	☐	☐	☐
	Applicability Notes					
	Keeping time-synchronization technology current includes managing vulnerabilities and patching the technology according to PCI DSS Requirements 6.3.1 and 6.3.3.					

PCI DSS Requirement		Expected Testing	Response* (Check one response for each requirement)			
			In Place	In Place with CCW	Not Applicable	Not in Place
10.6.2	Systems are configured to the correct and consistent time as follows: - One or more designated time servers are in use. - Only the designated central time server(s) receives time from external sources. - Time received from external sources is based on International Atomic Time or Coordinated Universal Time (UTC). - The designated time server(s) accept time updates only from specific industry-accepted external sources. - Where there is more than one designated time server, the time servers peer with one another to keep accurate time. - Internal systems receive time information only from designated central time server(s).	Examine system configuration settings for acquiring, distributing, and storing the correct time.	☒	☐	☐	☐
10.6.3	Time synchronization settings and data are protected as follows: - Access to time data is restricted to only personnel with a business need. - Any changes to time settings on critical systems are logged, monitored, and reviewed.	- Examine system configurations and time-synchronization settings and logs. - Observe processes.	☒	☐	☐	☐

Requirement 11: Test Security of Systems and Networks Regularly

Note: For SAQ A-EP, Requirement 11 applies to merchant servers and networks that host the payment page(s) provided from the merchant's website to the customer's browser.

PCI DSS Requirement		Expected Testing	Response* (Check one response for each requirement)			
			In Place	In Place with CCW	Not Applicable	Not in Place
11.3 External and internal vulnerabilities are regularly identified, prioritized, and addressed.						
11.3.2	External vulnerability scans are performed as follows: - At least once every three months. - By a PCI SSC Approved Scanning Vendor (ASV). - Vulnerabilities are resolved and <i>ASV Program Guide</i> requirements for a passing scan are met. - Rescans are performed as needed to confirm that vulnerabilities are resolved per the <i>ASV Program Guide</i> requirements for a passing scan.	Examine ASV scan reports.	☐	☒	☐	☐
Applicability Notes						
For the initial PCI DSS assessment against this requirement, it is not required that four passing scans be completed within 12 months if the assessor verifies: 1) the most recent scan result was a passing scan, 2) the entity has documented policies and procedures requiring scanning at least once every three months, and 3) vulnerabilities noted in the scan results have been corrected as shown in a re-scan(s). However, for subsequent years after the initial PCI DSS assessment, passing scans at least every three months must have occurred. ASV scanning tools can scan a vast array of network types and topologies. Any specifics about the target environment (for example, load balancers, third-party providers, ISPs, specific configurations, protocols in use, scan interference) should be worked out between the ASV and scan customer. Refer to the <i>ASV Program Guide</i> published on the PCI SSC website for scan customer responsibilities, scan preparation, etc.						

* Refer to the "Requirement Responses" section (page v) for information about these response options.

PCI DSS Requirement		Expected Testing	Response* (Check one response for each requirement)			
			In Place	In Place with CCW	Not Applicable	Not in Place
11.3.2.1	External vulnerability scans are performed after any significant change as follows: • Vulnerabilities that are scored 4.0 or higher by the CVSS are resolved. • Rescans are conducted as needed. • Scans are performed by qualified personnel and organizational independence of the tester exists (not required to be a QSA or ASV).	• Examine change control documentation. • Interview personnel. • Examine external scan, and as applicable rescan reports.	☒	☐	☐	☐
11.4 External and internal penetration testing is regularly performed, and exploitable vulnerabilities and security weaknesses are corrected.						
11.4.1	A penetration testing methodology is defined, documented, and implemented by the entity, and includes: • Industry-accepted penetration testing approaches. • Coverage for the entire CDE perimeter and critical systems. • Testing from both inside and outside the network. • Testing to validate any segmentation and scope-reduction controls. • Application-layer penetration testing to identify, at a minimum, the vulnerabilities listed in Requirement 6.2.4. • Network-layer penetration tests that encompass all components that support network functions as well as operating systems. • Review and consideration of threats and vulnerabilities experienced in the last 12 months. • Documented approach to assessing and addressing the risk posed by exploitable vulnerabilities and security weaknesses found during penetration testing. • Retention of penetration testing results and remediation activities results for at least 12 months.	• Examine documentation. • Interview personnel.	☒	☐	☐	☐
Applicability Notes (continued)						

PCI DSS Requirement		Expected Testing	Response* (Check one response for each requirement)			
			In Place	In Place with CCW	Not Applicable	Not in Place
11.4.1 (cont.)	Testing from inside the network (or “internal penetration testing”) means testing from both inside the CDE and into the CDE from trusted and untrusted internal networks. Testing from outside the network (or “external penetration testing”) means testing the exposed external perimeter of trusted networks, and critical systems connected to or accessible to public network infrastructures.					
11.4.3	External penetration testing is performed: - Per the entity’s defined methodology. - At least once every 12 months. - After any significant infrastructure or application upgrade or change. - By a qualified internal resource or qualified external third-party. - Organizational independence of the tester exists (not required to be a QSA or ASV).	- Examine scope of work. - Examine results from the most recent external penetration test. - Interview responsible personnel.	☐	☐	☐	☒
11.4.4	Exploitable vulnerabilities and security weaknesses found during penetration testing are corrected as follows: - In accordance with the entity’s assessment of the risk posed by the security issue as defined in Requirement 6.3.1. - Penetration testing is repeated to verify the corrections.	Examine penetration testing results.	☐	☐	☐	☒

PCI DSS Requirement		Expected Testing	Response* (Check one response for each requirement)			
			In Place	In Place with CCW	Not Applicable	Not in Place
11.4.5	If segmentation is used to isolate the CDE from other networks, penetration tests are performed on segmentation controls as follows: - At least once every 12 months and after any changes to segmentation controls/methods. - Covering all segmentation controls/methods in use. - According to the entity's defined penetration testing methodology. - Confirming that the segmentation controls/methods are operational and effective, and isolate the CDE from all out-of-scope systems. - Confirming effectiveness of any use of isolation to separate systems with differing security levels (see Requirement 2.2.3). - Performed by a qualified internal resource or qualified external third party. - Organizational independence of the tester exists (not required to be a QSA or ASV).	- Examine segmentation controls. - Review penetration-testing methodology. - Examine the results from the most recent penetration test. - Interview responsible personnel.	☒	☐	☐	☐
11.5 Network intrusions and unexpected file changes are detected and responded to.						
11.5.1	Intrusion-detection and/or intrusion-prevention techniques are used to detect and/or prevent intrusions into the network as follows: - All traffic is monitored at the perimeter of the CDE. - All traffic is monitored at critical points in the CDE. - Personnel are alerted to suspected compromises. - All intrusion-detection and prevention engines, baselines, and signatures are kept up to date.	- Examine system configurations and network diagrams. - Examine system configurations. - Interview responsible personnel. - Examine vendor documentation.	☒	☐	☐	☐

PCI DSS Requirement		Expected Testing	Response* (Check one response for each requirement)			
			In Place	In Place with CCW	Not Applicable	Not in Place
11.5.2	A change-detection mechanism (for example, file integrity monitoring tools) is deployed as follows: - To alert personnel to unauthorized modification (including changes, additions, and deletions) of critical files. - To perform critical file comparisons at least once weekly.	- Examine system settings for the change-detection mechanism. - Examine monitored files. - Examine results from monitoring activities.	☒	☐	☐	☐
	Applicability Notes					
	For change-detection purposes, critical files are usually those that do not regularly change, but the modification of which could indicate a system compromise or risk of compromise. Change-detection mechanisms such as file integrity monitoring products usually come pre-configured with critical files for the related operating system. Other critical files, such as those for custom applications, must be evaluated and defined by the entity (that is, the merchant or service provider).					

PCI DSS Requirement	Expected Testing	Response* (Check one response for each requirement)				
		In Place	In Place with CCW	Not Applicable	Not in Place	
11.6 Unauthorized changes on payment pages are detected and responded to						
Note: For SAQ A-EP, Requirement 11.6.1 applies to merchant web servers that host the payment page(s) provided from the merchant's website to the customer's browser.						
11.6.1	A change- and tamper-detection mechanism is deployed as follows:					
	To alert personnel to unauthorized modification (including indicators of compromise, changes, additions, and deletions) to the security-impacting HTTP headers and the script contents of payment pages as received by the consumer browser.	☒	☐	☐	☐	
	The mechanism is configured to evaluate the received HTTP headers and payment pages.	☒	☐	☐	☐	
	- The mechanism functions are performed as follows: - At least once weekly OR - Periodically (at the frequency defined in the entity's targeted risk analysis, which is performed according to all elements specified in Requirement 12.3.1).	☒	☐	☐	☐	
Applicability Notes						

PCI DSS Requirement	Expected Testing	Response* (Check one response for each requirement)			
		In Place	In Place with CCW	Not Applicable	Not in Place
	This requirement also applies to entities with a webpage(s) that includes a TPSP's/payment processor's embedded payment page/form (for example, one or more inline frames or iframes.) This requirement does not apply to an entity for scripts in a TPSP's/payment processor's embedded payment page/form (for example, one or more iframes), where the entity includes a TPSP's/payment processor's payment page/form on its webpage. Scripts in the TPSP's/payment processor's embedded payment page/form are the responsibility of the TPSP/payment processor to manage in accordance with this requirement. The intention of this requirement is not that an entity installs software in the systems or browsers of its consumers, but rather that the entity uses techniques such as those described under Examples in the PCI DSS Guidance column to prevent and detect unexpected script activities. <i>This requirement is a best practice until 31 March 2025, after which it will be required and must be fully considered during a PCI DSS assessment.</i>				

SAQ Completion Guidance:

Where the merchant server redirects customers from the merchant website to a TPSP/payment processor (for example, with a URL redirect), the merchant marks this requirement as Not Applicable and completes Appendix C: Explanation of Requirements Noted as Not Applicable.

Maintain an Information Security Policy

Requirement 12: Support Information Security with Organizational Policies and Programs

Note: Requirement 12 specifies that merchants have information security policies for their personnel, but these policies can be as simple or complex as needed for the size and complexity of the merchant's operations. The policy document must be provided to all personnel so they are aware of their responsibilities for protecting payment terminals, any paper documents with cardholder data and/or sensitive authentication data, etc. If a merchant has no employees, then it is expected that the merchant understands and acknowledges their responsibility for security within their store(s).

PCI DSS Requirement		Expected Testing	Response* (Check one response for each requirement)			
			In Place	In Place with CCW	Not Applicable	Not in Place
12.1 A comprehensive information security policy that governs and provides direction for protection of the entity's information assets is known and current.						
12.1.1	An overall information security policy is: - Established. - Published. - Maintained. - Disseminated to all relevant personnel, as well as to relevant vendors and business partners.	- Examine the information security policy. - Interview personnel.	☒	☐	☐	☐
12.1.2	The information security policy is: - Reviewed at least once every 12 months. - Updated as needed to reflect changes to business objectives or risks to the environment.	- Examine the information security policy. - Interview responsible personnel.	☒	☐	☐	☐

SAQ Completion Guidance:

Selection of any of the In Place responses for Requirements 12.1.1 and 12.1.2 means that the merchant has a security policy that is reasonable for the size and complexity of the merchant's operations, and that the policy is reviewed at least once every 12 months and updated if needed.

* Refer to the "Requirement Responses" section (page v) for information about these response options.

PCI DSS Requirement		Expected Testing	Response* (Check one response for each requirement)			
			In Place	In Place with CCW	Not Applicable	Not in Place
12.1.3	The security policy clearly defines information security roles and responsibilities for all personnel, and all personnel are aware of and acknowledge their information security responsibilities.	- Examine the information security policy. - Interview responsible personnel. - Examine documented evidence.	☒	☐	☐	☐
SAQ Completion Guidance: Selection of any of the In Place responses for Requirement 12.1.3 means that the merchant's security policy defines basic security responsibilities for all personnel, consistent with the size and complexity of the merchant's operations. For example, security responsibilities could be defined according to basic responsibilities by employee levels, such as the responsibilities expected of a manager/owner and those expected of clerks.						
12.1.4	Responsibility for information security is formally assigned to a Chief Information Security Officer or other information security knowledgeable member of executive management.	Examine the information security policy.	☒	☐	☐	☐

PCI DSS Requirement		Expected Testing	Response* (Check one response for each requirement)			
			In Place	In Place with CCW	Not Applicable	Not in Place
12.3 Risks to the cardholder data environment are formally identified, evaluated, and managed.						
12.3.1	For each PCI DSS requirement that specifies completion of a targeted risk analysis, the analysis is documented and includes: • Identification of the assets being protected. • Identification of the threat(s) that the requirement is protecting against. • Identification of factors that contribute to the likelihood and/or impact of a threat being realized. • Resulting analysis that determines, and includes justification for, how the frequency or processes defined by the entity to meet the requirement minimize the likelihood and/or impact of the threat being realized. • Review of each targeted risk analysis at least once every 12 months to determine whether the results are still valid or if an updated risk analysis is needed. • Performance of updated risk analyses when needed, as determined by the annual review.	• Examine documented policies and procedures.	☒	☐	☐	☐
Applicability Notes						
This requirement is a best practice until 31 March 2025, after which it will be required and must be fully considered during a PCI DSS assessment.						

PCI DSS Requirement		Expected Testing	Response* (Check one response for each requirement)			
			In Place	In Place with CCW	Not Applicable	Not in Place
12.6 Security awareness education is an ongoing activity.						
12.6.1	A formal security awareness program is implemented to make all personnel aware of the entity's information security policy and procedures, and their role in protecting the cardholder data.	Examine the security awareness program.	☒	☐	☐	☐
SAQ Completion Guidance: Selection of any of the In Place responses for Requirement 12.6.1 means that the merchant has a security awareness program in place, consistent with the size and complexity of the merchant's operations. For example, a simple awareness program could be a flyer posted in the back office, or a periodic e-mail sent to all employees. Examples of awareness program messaging include descriptions of security tips all employees should follow, such as how to lock doors and storage containers.						
12.6.3.1	Security awareness training includes awareness of threats and vulnerabilities that could impact the security of cardholder data and/or sensitive authentication data, including but not limited to: - Phishing and related attacks. - Social engineering.	Examine security awareness training content.	☒	☐	☐	☐
Applicability Notes						
See Requirement 5.4.1 in PCI DSS for guidance on the difference between technical and automated controls to detect and protect users from phishing attacks, and this requirement for providing users security awareness training about phishing and social engineering. These are two separate and distinct requirements, and one is not met by implementing controls required by the other one.						
<i>This requirement is a best practice until 31 March 2025, after which it will be required and must be fully considered during a PCI DSS assessment.</i>						

PCI DSS Requirement		Expected Testing	Response* (Check one response for each requirement)			
			In Place	In Place with CCW	Not Applicable	Not in Place
12.8 Risk to information assets associated with third-party service provider (TPSP) relationships is managed.						
12.8.1	A list of all third-party service providers (TPSPs) with which account data is shared or that could affect the security of account data is maintained, including a description for each of the services provided. Applicability Notes The use of a PCI DSS compliant TPSP does not make an entity PCI DSS compliant, nor does it remove the entity's responsibility for its own PCI DSS compliance.	- Examine policies and procedures. - Examine list of TPSPs.	☒	☐	☐	☐
12.8.2	Written agreements with TPSPs are maintained as follows: - Written agreements are maintained with all TPSPs with which account data is shared or that could affect the security of the CDE. - Written agreements include acknowledgments from TPSPs that TPSPs are responsible for the security of account data the TPSPs possess or otherwise store, process, or transmit on behalf of the entity, or to the extent that the TPSP could impact the security of the entity's cardholder data and/or sensitive authentication data. Applicability Notes The exact wording of an agreement will depend on the details of the service being provided, and the responsibilities assigned to each party. The agreement does not have to include the exact wording provided in this requirement. The TPSP's written acknowledgment is a confirmation that states the TPSP is responsible for the security of the account data it may store, process, or transmit on behalf of the customer or to the extent the TPSP may impact the security of a customer's cardholder data and/or sensitive authentication data. Evidence that a TPSP is meeting PCI DSS requirements (is not the same as a written acknowledgment specified in this requirement. For example, a PCI DSS Attestation of Compliance (AOC), a declaration on a company's website, a policy statement, a responsibility matrix, or other evidence not included in a written agreement is not a written acknowledgment.	- Examine policies and procedures. - Examine written agreements with TPSPs.	☒	☐	☐	☐

PCI DSS Requirement		Expected Testing	Response* (Check one response for each requirement)			
			In Place	In Place with CCW	Not Applicable	Not in Place
12.8.3	An established process is implemented for engaging TPSPs, including proper due diligence prior to engagement.	- Examine policies and procedures. - Examine evidence. - Interview responsible personnel.	☒	☐	☐	☐
12.8.4	A program is implemented to monitor TPSPs' PCI DSS compliance status at least once every 12 months.	- Examine policies and procedures. - Examine documentation. - Interview responsible personnel.	☒	☐	☐	☐
	Applicability Notes Where an entity has an agreement with a TPSP for meeting PCI DSS requirements on behalf of the entity (for example, via a firewall service), the entity must work with the TPSP to make sure the applicable PCI DSS requirements are met. If the TPSP does not meet those applicable PCI DSS requirements, then those requirements are also "not in place" for the entity.					
12.8.5	Information is maintained about which PCI DSS requirements are managed by each TPSP, which are managed by the entity, and any that are shared between the TPSP and the entity.	- Examine policies and procedures. - Examine documentation. - Interview responsible personnel.	☒	☐	☐	☐

SAQ Completion Guidance:

Selection of any of the In Place responses for requirements at 12.8.1 through 12.8.5 means that the merchant has a list of, and agreements with, service providers it shares account data with or that could impact the security of the merchant's cardholder data environment. For example, such agreements would be applicable if a merchant uses a document-retention company to store paper documents that include account data or if a merchant's vendor accesses merchant systems remotely to perform maintenance.

PCI DSS Requirement	Expected Testing	Response* (Check one response for each requirement)				
		In Place	In Place with CCW	Not Applicable	Not in Place	
12.10 Suspected and confirmed security incidents that could impact the CDE are responded to immediately.						
12.10.1	An incident response plan exists and is ready to be activated in the event of a suspected or confirmed security incident. The plan includes, but is not limited to: • Roles, responsibilities, and communication and contact strategies in the event of a suspected or confirmed security incident, including notification of payment brands and acquirers, at a minimum. • Incident response procedures with specific containment and mitigation activities for different types of incidents. • Business recovery and continuity procedures. • Data backup processes. • Analysis of legal requirements for reporting compromises. • Coverage and responses of all critical system components. • Reference or inclusion of incident response procedures from the payment brands.	• Examine the incident response plan. • Interview personnel. • Examine documentation from previously reported incidents.	☒	☐	☐	☐
SAQ Completion Guidance: <i>Selection of any of the In Place responses for Requirement 12.10.1 means that the merchant has documented an incident response and escalation plan to be used for emergencies, consistent with the size and complexity of the merchant’s operations. For example, such a plan could be a simple document posted in the back office that lists who to call in the event of various situations with an annual review to confirm it is still accurate, but could extend all the way to a full incident response plan including backup “hotsite” facilities and thorough annual testing. This plan should be readily available to all personnel as a resource in an emergency.</i>						
12.10.3	Specific personnel are designated to be available on a 24/7 basis to respond to suspected or confirmed security incidents.	• Interview responsible personnel. • Examine documentation.	☒	☐	☐	☐

Appendix A: Additional PCI DSS Requirements

Appendix A1: Additional PCI DSS Requirements for Multi-Tenant Service Providers

This Appendix is not used for merchant assessments.

Appendix A2: Additional PCI DSS Requirements for Entities using SSL/early TLS for Card-Present POS POI Terminal Connections

This Appendix is not used for SAQ A-EP merchant assessments.

Appendix A3: Designated Entities Supplemental Validation (DESV)

This Appendix applies only to entities designated by a payment brand(s) or acquirer as requiring additional validation of existing PCI DSS requirements. Entities required to validate to this Appendix should use the DESV Supplemental Reporting Template and Supplemental Attestation of Compliance for reporting and consult with the applicable payment brand and/or acquirer for submission procedures.

Appendix B: Compensating Controls Worksheet

This Appendix must be completed to define compensating controls for any requirement where In Place with CCW was selected.

Note: Only entities that have a legitimate and documented technological or business constraint can consider the use of compensating controls to achieve compliance.

Refer to Appendices B and C in PCI DSS for information about compensating controls and guidance on how to complete this worksheet.

Requirement Number and Definition:

	Information Required	Explanation
1. Constraints	Document the legitimate technical or business constraints precluding compliance with the original requirement.	Cloudflare Free Managed Ruleset is not active on this zone (verified empirically via Cloudflare dashboard 2026-09-13 — documented "No Managed rules created" with upgrade prompt). Cloudflare Pro (\$20/month) would enable full WAF Managed Ruleset. Free-tier http.request.body.raw inspection requires WAF Advanced (paid add-on). Budget constraint for portfolio lab.
2. Definition of Compensating Controls	Define the compensating controls: explain how they address the objectives of the original control and the increased risk, if any.	(1) Cloudflare Custom Rules (Free tier): Rule 1 blocks webhook requests missing Stripe-Signature header; Rule 2 blocks injection patterns in query strings on /billing routes; Rule 3 rate-limits /billing/create-checkout-session (19 req/10s, 10s block duration — Free tier fixed thresholds). (2) Stripe HMAC-SHA256 webhook signature verification on every webhook request before processing. (3) Keycloak JWT validation (RS256, issuer, audience check) on all authenticated routes — unauthenticated request to /billing/create-checkout-session is rejected before any body is processed. (4) GitLab CI SAST on every commit scans for injection vulnerabilities in the application code.

3. Objective	Define the objective of the original control.	Automated detection and prevention of web-based attacks on the payment page server
	Identify the objective met by the compensating control. Note: <i>This can be, but is not required to be, the stated Customized Approach Objective listed for this requirement in PCI DSS.</i>	Prevent successful exploitation of the two public POST endpoints through layered header-based filtering, authentication-based gatekeeping, and cryptographic signature verification — achieving equivalent risk reduction for the actual attack surface.
4. Identified Risk	Identify any additional risk posed by the lack of the original control.	Cloudflare Custom Rules provide query-string and header-based filtering only — no body content inspection at the edge. Coarse-grained rate limiting (Free tier). Residual risk: a sophisticated body-payload attack against /billing/create-checkout-session that passes JWT authentication would not be blocked at the edge.
5. Validation of Compensating Controls	Define how the compensating controls were validated and tested.	Custom Rules verified deployed in Cloudflare Security → Security rules. Stripe signature verification tested via integration (valid and invalid signature test events). JWT validation tested by submitting requests with expired/invalid tokens.
6. Maintenance	Define process(es) and controls in place to maintain compensating controls.	Cloudflare Custom Rules reviewed at every significant change to API surface. Stripe signature verification is code-level and covered by CI. Upgrade to Cloudflare Pro or WAF Advanced if project scope expands to warrant it.

Appendix D: Explanation of Requirements Noted as Not Tested

This Appendix is not used for SAQ A-EP merchant assessments.

Section 3: Validation and Attestation Details

Part 3. PCI DSS Validation

This AOC is based on results noted in SAQ A-EP (Section 2), dated (Self-assessment completion date 2026-09-23).

Based on the results documented in the SAQ A-EP noted above, each signatory identified in any of Parts 3b-3d, as applicable, assert(s) the following compliance status for the merchant identified in Part 2 of this document.

Select one:

☒	Compliant: All sections of the PCI DSS SAQ are complete and all requirements are marked as being either 1) In Place, 2) In Place with CCW, or 3) Not Applicable, resulting in an overall COMPLIANT rating; thereby <i>WorkUp</i>) has demonstrated compliance with all PCI DSS requirements included in this SAQ.								
☐	Non-Compliant: Not all sections of the PCI DSS SAQ are complete, or one or more requirements are marked as Not in Place, resulting in an overall NON-COMPLIANT rating, thereby <i>(Merchant Company Name)</i> has not demonstrated compliance with the PCI DSS requirements included in this SAQ. Target Date for Compliance: YYYY-MM-DD A merchant submitting this form with a Non-Compliant status may be required to complete the Action Plan in Part 4 of this document. Confirm with the entity to which this AOC will be submitted <i>before completing Part 4</i>.								
☐	Compliant but with Legal exception: One or more assessed requirements in the PCI DSS SAQ are marked as Not in Place due to a legal restriction that prevents the requirement from being met and all other requirements are marked as being either 1) In Place, 2) In Place with CCW, or 3) Not Applicable, resulting in an overall COMPLIANT BUT WITH LEGAL EXCEPTION rating; thereby <i>(Merchant Company Name)</i> has demonstrated compliance with all PCI DSS requirements included in this SAQ except those noted as Not in Place due to a legal restriction. This option requires additional review from the entity to which this AOC will be submitted. <i>If selected, complete the following:</i> <table border="1" data-bbox="297 1344 1446 1566"> <thead> <tr> <th data-bbox="297 1344 677 1419">Affected Requirement</th> <th data-bbox="677 1344 1446 1419">Details of how legal constraint prevents requirement from being met</th> </tr> </thead> <tbody> <tr> <td data-bbox="297 1419 677 1470"></td> <td data-bbox="677 1419 1446 1470"></td> </tr> <tr> <td data-bbox="297 1470 677 1520"></td> <td data-bbox="677 1470 1446 1520"></td> </tr> <tr> <td data-bbox="297 1520 677 1566"></td> <td data-bbox="677 1520 1446 1566"></td> </tr> </tbody> </table>	Affected Requirement	Details of how legal constraint prevents requirement from being met						
Affected Requirement	Details of how legal constraint prevents requirement from being met								

Part 3a. Merchant Acknowledgement

Signatory(s) confirms:

(Select all that apply)

☒	PCI DSS Self-Assessment Questionnaire A-EP, Version 4.0.1, was completed according to the instructions therein.
☒	All information within the above-referenced SAQ and in this attestation fairly represents the results of the merchant's assessment in all material respects.
☒	PCI DSS controls will be maintained at all times, as applicable to the merchant's environment.

Part 3b. Merchant Attestation

VICTOR OJEJE

Signature of Merchant Executive Officer ↑	Date: 2026-09-23
Merchant Executive Officer Name: Victor Ogechukwu Ojeje	Title: Platform Operator

Part 3c. Qualified Security Assessor (QSA) Acknowledgement

If a QSA was involved or assisted with this assessment, indicate the role performed:	☐ QSA performed testing procedures.
	☐ QSA provided other assistance. If selected, describe all role(s) performed:

Signature of Lead QSA ↑	Date: YYYY-MM-DD
-------------------------	------------------

Lead QSA Name:

Signature of Duly Authorized Officer of QSA Company ↑	Date: YYYY-MM-DD
Duly Authorized Officer Name:	QSA Company:

Part 3d. PCI SSC Internal Security Assessor (ISA) Involvement

If an ISA(s) was involved or assisted with this assessment, indicate the role performed:	☐ ISA(s) performed testing procedures.
	☐ ISA(s) provided other assistance. If selected, describe all role(s) performed:

Part 4. Action Plan for Non-Compliant Requirements

Only complete Part 4 upon request of the entity to which this AOC will be submitted, and only if the Assessment has a Non-Compliant status noted in Section 3.

If asked to complete this section, select the appropriate response for “Compliant to PCI DSS Requirements” for each requirement below. For any “No” responses, include the date the merchant expects to be compliant with the requirement and a brief description of the actions being taken to meet the requirement.

PCI DSS Requirement *	Description of Requirement	Compliant to PCI DSS Requirements (Select One)		Remediation Date and Actions (If “NO” selected for any Requirement)
		YES	NO	
1	Install and maintain network security controls	☐	☐	
2	Apply secure configurations to all system components	☐	☐	
3	Protect stored account data	☐	☐	
4	Protect cardholder data with strong cryptography during transmission over open, public networks	☐	☐	
5	Protect all systems and networks from malicious software	☐	☐	
6	Develop and maintain secure systems and software	☐	☐	
7	Restrict access to system components and cardholder data by business need to know	☐	☐	
8	Identify users and authenticate access to system components	☐	☐	
9	Restrict physical access to cardholder data	☐	☐	
10	Log and monitor all access to system components and cardholder data	☐	☐	
11	Test security systems and networks regularly	☐	☐	
12	Support information security with organizational policies and programs	☐	☐	

* PCI DSS Requirements indicated above refer to the requirements in Section 2 of this SAQ.

Note: The PCI Security Standards Council is a global standards body that provides resources for payment security professionals developed collaboratively with our stakeholder community. Our materials are accepted in numerous compliance programs worldwide. Please check with your individual compliance-accepting organization to ensure that this form is acceptable in its program. For more information about PCI SSC and our stakeholder community please visit: https://www.pcisecuritystandards.org/about_us/.